

TỔNG CỤC II
HỌC VIỆN KHOA HỌC QUÂN SỰ

ĐỀ CƯƠNG CHI TIẾT VỀ SÁNG KIẾN
BỘ CÔNG CỤ BẢO ĐẢM AN TOÀN THÔNG TIN VÀ QUYỀN RIÊNG
TƯ DỮ LIỆU TRÊN THIẾT BỊ DI ĐỘNG (SECUREVAULT MOBILE)

Hà Nội, năm 2026

ĐỀ CƯƠNG CHI TIẾT VỀ SÁNG KIẾN

Bộ công cụ bảo đảm an toàn thông tin và quyền riêng tư dữ liệu trên thiết bị di động (SecureVault Mobile)

LỜI DẪN

Tài liệu này là phần trình bày đầy đủ của sáng kiến, đi kèm bản Thuyết minh. Bản Thuyết minh được giới hạn dưới 20 trang để hội đồng nắm nhanh sáng kiến là gì, mới ở đâu và có giá trị gì; vì vậy phần lập luận thiết kế, các phương án đã cân nhắc, cấu trúc dữ liệu, mô tả từng chức năng và toàn bộ bằng chứng kiểm chứng được đưa về đây.

Nhóm tác giả chọn mạch trình bày theo đúng trình tự công việc đã thực sự diễn ra: xác định ràng buộc và nhu cầu thực tiễn; khảo sát cái đã có để tìm khoảng trống; đặt nguyên lý thiết kế; ra các quyết định kiến trúc và ghi lại phương án bị loại cùng lý do; giải quyết từng vấn đề kỹ thuật; dựng sản phẩm; kiểm chứng; và cuối cùng là đánh giá giá trị cùng giới hạn. Mạch này cho phép người đọc kiểm tra không chỉ *sản phẩm có gì* mà cả *vì sao lại làm như vậy*.

Một quy ước xuyên suốt cả hồ sơ: mọi con số kỹ thuật trong tài liệu đều được sinh tự động từ mã nguồn, gói cài đặt và nhật ký kiểm thử, không nhập tay. Những gì chưa kiểm chứng được thì ghi rõ là chưa kiểm chứng, kèm quy trình để đơn vị tự xác nhận.

MỤC LỤC

Nhấn chuột phải vào đây rồi chọn “Cập nhật trường” để hiện mục lục.

PHẦN I. VẤN ĐỀ THỰC TIỄN VÀ BÀI TOÁN ĐẶT RA

1.1. Ràng buộc nghiệp vụ — điểm xuất phát của sáng kiến

Sáng kiến này bắt đầu từ một ràng buộc chứ không từ một ý tưởng công nghệ. Trong môi trường công tác ở Học viện Khoa học Quân sự và các cơ quan, đơn vị có yêu cầu cao về bảo vệ thông tin, việc quản lý, lưu trữ và chuyển giao tài liệu mật, tài liệu nội bộ phải tuân thủ nghiêm ngặt quy định hiện hành; đơn vị không cho phép đưa tài liệu mật và tài liệu nội bộ lên thiết bị di động cá nhân.

Ràng buộc đó được nhóm tác giả xác định ngay từ đầu và giữ nguyên trong suốt quá trình thiết kế. Nó loại bỏ một hướng đi tưởng như hiển nhiên — làm một ứng dụng để mang tài liệu công tác theo người — và buộc sáng kiến phải tìm giá trị ở chỗ khác. Kết quả là hai nhu cầu nằm hoàn toàn trong ranh giới cho phép, trình bày ở mục tiếp theo.

Phạm vi tự giới hạn của sáng kiến

Sáng kiến không đề xuất, không hàm ý và không tạo cơ sở cho việc thay đổi hay nói lỏng bất kỳ quy định nào về bảo vệ bí mật.

Việc một tài liệu cụ thể có được phép lưu trữ, xử lý hay chuyển giao qua một phương thức nhất định hay không hoàn toàn do quy định hiện hành và người có thẩm quyền quyết định. Công cụ chỉ bổ sung biện pháp kỹ thuật trong phạm vi hoạt động đã được phép.

1.2. Hai nhu cầu thực tiễn

Nhu cầu thứ nhất — huấn luyện. Bảo vệ dữ liệu bằng mật mã là nội dung quan trọng trong chương trình đào tạo an toàn thông tin, bảo đảm an toàn tình báo trên không gian mạng. Nhưng việc học hiện nay chủ yếu dừng ở cơ sở lý thuyết, thuật toán và công cụ chạy trên máy tính. Trong khi đó thiết bị di động mới là môi trường mà học viên sẽ phải bảo vệ dữ liệu nhiều nhất sau khi ra trường. Khoảng cách giữa điều được học và môi trường thực tế làm giảm hiệu quả huấn luyện: học viên biết nguyên lý nhưng chưa từng thao tác, chưa từng nhìn thấy một hệ thống an toàn hoàn chỉnh vận hành ra sao và vì sao nó được thiết kế như vậy.

Điều cần có là một môi trường thực hành an toàn: học viên trực tiếp mã hoá tệp bằng mật khẩu, tạo và kiểm tra chữ ký số, chia khoá theo ngưỡng, xoá siêu dữ liệu, kiểm tra toàn vẹn — và quan sát được kết quả ngay trên thiết bị. Quan trọng hơn, học

viên phải thấy được cả *giới hạn* của mỗi biện pháp, vì hiểu sai về giới hạn của một công cụ an toàn còn nguy hiểm hơn không dùng công cụ nào.

Nhu cầu thứ hai — tình huống khẩn cấp, bất khả kháng. Trong công tác vẫn phát sinh trường hợp một số tài liệu đặc thù buộc phải chuyển gấp qua không gian mạng khi không còn phương án nào khác kịp thời hạn. Đây là tình huống rủi ro nhất: tệp rời khỏi tầm kiểm soát của người gửi và đi qua hạ tầng không do đơn vị quản lý, nguy cơ bị chặn bắt, sao chép hoặc tiếp cận trái phép tăng lên.

Trong những trường hợp đã được cấp có thẩm quyền cho phép chuyển giao, cán bộ cần một công cụ tin cậy và kiểm chứng được để tự trang bị thêm lớp bảo vệ cho tệp trước khi gửi. Bốn cơ chế tương ứng bốn nguy cơ: mã hoá bằng mật khẩu để nội dung không đọc được khi tệp bị tiếp cận trái phép; ký số để bên nhận tự xác minh nguồn gốc và tính toàn vẹn mà không phải tin vào kênh truyền; xoá siêu dữ liệu để không vô tình gửi kèm toạ độ định vị và thông tin thiết bị; chia bí mật theo ngưỡng để một kênh bị lộ vẫn chưa đủ khôi phục dữ liệu. Mục tiêu cuối cùng rất cụ thể: nếu tệp bị chặn bắt trên đường truyền thì bên chặn bắt thu được bản mã chứ không phải nội dung.



Hình 1. Hai nhu cầu thực tiễn mà sáng kiến hướng tới và bốn nhóm nguy cơ tương ứng

1.3. Khảo sát các nhóm giải pháp đã biết

Trước khi xây dựng, nhóm tác giả khảo sát các nhóm giải pháp hiện có theo hướng tiếp cận chức năng, nhằm xác định chính xác khoảng trống cần lấp. Phân tích dưới đây cố gắng giữ khách quan: mỗi nhóm đều giải quyết tốt bài toán mà nó được thiết kế cho: vấn đề là không nhóm nào giải quyết trọn vẹn bài toán đang xét.

Bảng 1. So sánh các nhóm giải pháp đã biết với nhu cầu đặt ra

Nhóm giải pháp	Ưu điểm	Nhược điểm chưa được khắc phục
Mã hoá toàn thiết bị của hệ điều hành (FBE/FDE Android)	Bảo vệ dữ liệu khi thiết bị ở trạng thái tắt hoặc chưa mở khoá lần đầu; trong suốt với người dùng	Khi máy đã mở khoá, mọi ứng dụng và người cầm máy đều thấy dữ liệu ở dạng rõ; hoàn toàn không bảo vệ được tệp khi đưa ra khỏi thiết bị
Ứng dụng “khóa tệp”, “kết riêng tư” trên kho ứng dụng	Giao diện thuận tiện, cài đặt nhanh, nhiều lựa chọn	Phần lớn mã nguồn đóng nên không kiểm chứng được thuật toán và cách quản lý khoá; nhiều ứng dụng yêu cầu quyền truy cập mạng hoặc đồng bộ đám mây; định dạng riêng khiến người dùng bị khoá vào một sản phẩm
Trình quản lý mật khẩu mã nguồn mở (KeePassDX, Bitwarden...)	Quản lý thông tin đăng nhập rất tốt, kiểm chứng được	Được thiết kế cho mật khẩu, không nhằm xử lý tệp, ảnh, tài liệu và không có các nghiệp vụ ký số, kiểm tra toàn vẹn, chia khoá phục hồi, xử lý siêu dữ liệu
Công cụ mật mã dòng lệnh (age, GPG, OpenSSL, VeraCrypt)	Thuật toán tin cậy, được cộng đồng soi xét lâu dài	Không có bản dùng được trên di động do rào cản kiến trúc nền tảng (mục 3.1); giao diện dòng lệnh không phù hợp với người dùng không chuyên
Ứng dụng nhắn tin mã hoá đầu-cuối	Bảo vệ rất tốt dữ liệu trên đường truyền	Không bảo vệ dữ liệu ở trạng thái lưu trữ trên máy; dữ liệu vẫn đi qua hạ tầng của nhà cung cấp dịch vụ nước ngoài
Giải pháp quản lý thiết bị / chống thất thoát dữ liệu (MDM/DLP)	Quản lý tập trung, phù hợp quy mô lớn	Cần hạ tầng máy chủ, chi phí bản quyền và phụ thuộc nhà cung cấp; khó triển khai cho nhu cầu cá nhân và nhóm nhỏ

Nhận xét rút ra không phải là “các giải pháp hiện có kém”, mà là chúng được thiết kế cho những bài toán khác. Hai nhu cầu ở mục 1.2 đòi hỏi đồng thời: bảo vệ theo tệp (chứ không theo thiết bị), kiểm chứng được (chứ không phải tin vào nhà cung cấp), chạy được trên di động, và đủ nhiều nghiệp vụ để dùng làm học cụ. Không nhóm nào có đủ bốn.

Bảng 2. Ma trận đối chiếu theo tiêu chí kiểm tra được

Tiêu chí	Mã hoá toàn thiết bị	Ứng dụng kết thương mại	Công cụ dòng lệnh	SecureVault Mobile
Chạy được trên Android	Có	Có	Không	Có

Không yêu cầu quyền mạng	Có	Thường không	Có	Có
Mã nguồn kiểm tra được	Một phần	Thường không	Có	Có
Có bộ kiểm thử công khai	Không rõ	Không	Có	Có
Bảo vệ tệp sau khi rời thiết bị	Không	Một phần	Có	Có
Ký số và kiểm tra nguồn gốc	Không	Thường không	Có	Có
Chia khoá phục hồi theo ngưỡng	Không	Thường không	Một phần	Có
Xử lý siêu dữ liệu ẩn trong ảnh	Không	Thường không	Có	Có
Định dạng tệp theo chuẩn mở	Không áp dụng	Thường không	Có	Có
Dùng được làm học cụ giảng dạy	Hạn chế	Hạn chế	Có	Có

Cột SecureVault Mobile chỉ đối chiếu với chức năng đã hiện thực và kiểm chứng; cách kiểm chứng từng dòng trình bày ở Phần V.

1.4. Phát biểu bài toán

Từ khảo sát trên, bài toán được phát biểu như sau: *xây dựng một bộ công cụ bảo vệ dữ liệu chạy hoàn toàn trên thiết bị di động Android, đồng thời đáp ứng năm yêu cầu dưới đây, mà đến thời điểm khảo sát chưa có sản phẩm nào đáp ứng đủ:*

- **Yêu cầu 1 — hoạt động hoàn toàn trên thiết bị.** Không yêu cầu quyền truy cập mạng, không tài khoản, không đồng bộ đám mây. Yêu cầu này phải được bảo đảm bằng ràng buộc kỹ thuật kiểm tra được, không phải bằng lời cam kết.
- **Yêu cầu 2 — kiểm chứng được.** Mã nguồn kiểm soát được, thuật toán công khai, có bộ kiểm thử tự động để bên thứ ba chạy lại và tự kết luận.
- **Yêu cầu 3 — gộp nhiều nghiệp vụ trong một ứng dụng thống nhất.** Người dùng không phải ghép nhiều công cụ rời rạc cho một quy trình bảo vệ dữ liệu.
- **Yêu cầu 4 — tệp đầu ra theo chuẩn mở.** Bảo đảm tương thích và thuận tiện khi chuyển đổi giữa các sản phẩm, nền tảng khác nhau; người dùng không bị khoá vào một sản phẩm.
- **Yêu cầu 5 — dùng được làm học cụ.** Mỗi nhóm chức năng ứng với một nguyên lý trong chương trình, đồng thời sản phẩm vẫn phải đạt chuẩn kỹ thuật của một công cụ dùng thật, không phải bản mô phỏng.

Yêu cầu 5 đáng chú ý ở chỗ nó thường mâu thuẫn với bốn yêu cầu còn lại. Một sản phẩm dựng riêng để dạy học thường được đơn giản hoá tới mức không dùng được thật; ngược lại, một công cụ chuyên nghiệp thường quá phức tạp để đưa vào giờ thực hành. Cách hoá giải mâu thuẫn này chính là một trong những điểm sáng tạo của sáng kiến, trình bày ở mục 6.1 và 6.2.

1.5. Mô hình mối đe dọa

Một sản phẩm an toàn phải nói rõ nó bảo vệ chống lại cái gì và *không* bảo vệ chống lại cái gì. Nhóm tác giả xác lập mô hình mối đe dọa ngay từ giai đoạn thiết kế, trước khi viết mã, và giữ nó làm căn cứ cho mọi quyết định về sau. Các giả định nền:

- Thiết bị chạy hệ điều hành chưa bị chiếm quyền điều khiển ở mức nhân. Nếu giả định này sai thì mọi biện pháp trong phạm vi ứng dụng đều mất hiệu lực.
- Người dùng giữ được mật khẩu và các mảnh khoá phục hồi. Ứng dụng cố tình không lưu mật khẩu lâu dài, nên không có cửa sau nào để bù lại việc quên mật khẩu.
- Kẻ tấn công có thể lấy được tệp (kết, tệp đã khoá, mảnh khoá) nhưng không có mật khẩu; hoặc chặn bắt được tệp trên đường truyền.
- Các nguyên hàm mật mã được dùng (Argon2id, BLAKE3, age v1, XSalsa20-Poly1305, Ed25519, Shamir) là an toàn theo hiểu biết công khai hiện nay.

Bảng 3. Mô hình mối đe dọa đầy đủ: phạm vi bảo vệ và giới hạn

Tình huống	Có bảo vệ?	Giải thích
Mất hoặc thất lạc điện thoại khi máy đang khoá	Có	Dữ liệu trong kết ở dạng mã hoá; không có mật khẩu thì không mở được
Người khác mượn máy khi máy đã mở khoá	Có, một phần	Kết vẫn cần mật khẩu riêng; nhưng nếu phiên đang mở thì nội dung có thể xem được
Sao chép tệp kết ra khỏi thiết bị	Có	Tệp kết tự bảo vệ, mở ở nơi khác vẫn cần mật khẩu
Tệp bị sửa đổi hoặc hỏng trên đường truyền	Có	Chữ ký ràng buộc phát hiện mọi thay đổi, kể cả ghép phần đầu tệp này với nội dung tệp khác
Tệp bị chặn bắt khi buộc phải truyền gộp qua không gian mạng	Có	Tệp truyền đi ở dạng đã mã hoá có xác thực; bên chặn bắt thu được bản mã nhưng không có mật khẩu thì không đọc được nội dung
Bên nhận không chắc tệp có đúng do người gửi tạo ra	Có	Chữ ký số cho phép bên nhận tự xác minh nguồn gốc và tính

không		toàn vẹn, không cần tin vào kênh truyền
Ảnh chia sẻ mang theo tọa độ định vị	Có	Chức năng xóa siêu dữ liệu loại bỏ trước khi chia sẻ; có chức năng so sánh để người dùng tự kiểm tra kết quả
Lộ tệp do gửi nhầm qua ứng dụng khác	Có, một phần	Nếu gửi tệp kết thì bên nhận vẫn cần mật khẩu; nếu gửi tệp đã trích xuất thì không
Suy đoán mật khẩu từ khác biệt giữa các thông báo lỗi	Có	Quy tắc phân loại lỗi hợp nhất các trường hợp có thể dùng làm tín hiệu dò (mục 3.6)
Thiết bị đã bị chiếm quyền điều khiển ở mức hệ điều hành	Không	Phần mềm độc hại có quyền cao đọc được bộ nhớ tiến trình khi kết đang mở
Người dùng quên mật khẩu và không tạo mảnh phục hồi	Không	Hệ quả trực tiếp của nguyên tắc không lưu mật khẩu lâu dài — đây là đánh đổi có chủ ý, không phải thiếu sót
Kẻ tấn công cưỡng ép người dùng cung cấp mật khẩu	Không	Nằm ngoài phạm vi của biện pháp kỹ thuật

PHẦN II. NGUYÊN LÝ THIẾT KẾ VÀ CÁC QUYẾT ĐỊNH KIẾN TRÚC

2.1. Sáu nguyên lý và cách chuyển hoá thành ràng buộc kỹ thuật

Sáu nguyên lý dưới đây được xác lập trước khi viết dòng mã đầu tiên. Điểm mà nhóm tác giả coi trọng không phải bản thân các nguyên lý — chúng là hiểu biết chung của ngành — mà là việc mỗi nguyên lý được chuyển hoá thành một ràng buộc cụ thể trong phần mềm, và mỗi ràng buộc lại gắn với một cách kiểm tra. Nguyên lý chỉ nằm trong tài liệu thì sớm muộn cũng bị vi phạm khi phần mềm được sửa đổi; nguyên lý có cơ chế kiểm tra thì không.

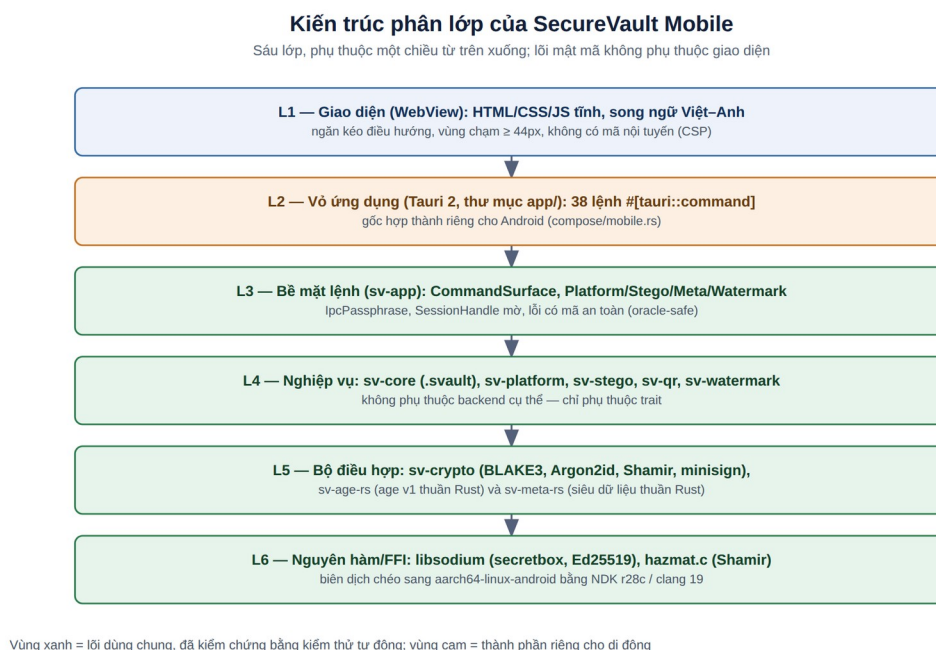
Bảng 4. Sáu nguyên lý thiết kế, cơ chế thực thi và cách kiểm tra

Nguyên lý	Cơ chế thực thi trong sản phẩm	Cách kiểm tra
Hoạt động ngoại tuyến tuyệt đối	Ứng dụng không khai báo quyền truy cập mạng trong AndroidManifest.xml. Đây là ràng buộc ở cấp hệ điều hành: không có quyền thì tiến trình không mở được kết nối, bất kể mã nguồn viết gì	Đọc tệp kê khai trong gói cài đặt đã đóng gói
Một lỗi bảo vệ dữ liệu dùng chung	Toàn bộ nghiệp vụ mật mã nằm trong lỗi gồm 15 thành phần độc lập, không thành phần nào dùng thư viện giao diện hay thư viện đặc thù nền tảng	Đọc quan hệ phụ thuộc khai báo của từng thành phần
Phụ thuộc một chiều theo lớp	Lớp trên dùng lớp dưới, không có chiều ngược lại. Lỗi chỉ phụ thuộc vào giao diện trừu tượng và quy ước xử lý, không phụ thuộc một cách triển khai cụ thể	Lỗi được kiểm thử độc lập với bản hiện thực giả lập; nếu lỗi lỡ phụ thuộc vào bản thật thì phép kiểm thử này không biên dịch được
Khi không bảo đảm an toàn thì không tiếp tục xử lý	Thành phần chưa sẵn sàng bị vô hiệu hoá và báo ngay lúc khởi động; dữ liệu ngoài phạm vi xử lý bị từ chối kèm mã lỗi xác định, thay vì trả về trạng thái thành công không đúng thực tế	Kiểm thử tình huống mô-đun không sẵn sàng và tình huống định dạng ngoài phạm vi
Thông báo lỗi không làm lộ thông tin bí mật	Sau khi chữ ký và khoá đã được kiểm tra xong, giải mã thất bại được báo là “tệp hỏng” thay vì “sai xác thực”; sai mật khẩu và sai mảnh khôi phục dùng chung một trạng thái lỗi	Kiểm thử đối chiếu thông báo giữa hai bản hiện thực của mô-đun mã hoá
Không lưu trữ bí mật lâu dài	Mật khẩu chỉ tồn tại trong bộ	Kiểm thử vòng đời phiên làm

	nhớ trong thời gian xử lý và được quản lý bằng kiểu dữ liệu tự xoá nội dung khi ra khỏi phạm vi sử dụng; khoá chính chỉ nằm trong bộ nhớ phiên và bị xoá khi người dùng khoá kết	việc
--	--	------

2.2. Kiến trúc phân lớp

Ứng dụng được tổ chức thành sáu lớp chức năng. Giao diện và lõi nghiệp vụ tách hẳn nhau: mọi yêu cầu từ giao diện xuống lõi đều phải đi qua 38 lệnh được kiểm soát thống nhất, không có đường truy cập trực tiếp nào khác. Ranh giới này là chỗ đặt các biện pháp bảo vệ: mật khẩu khi đi qua ranh giới được bọc trong kiểu dữ liệu tự xoá; phiên làm việc chỉ được tham chiếu bằng một mã định danh ngẫu nhiên không mang thông tin bí mật, nên kể cả khi lộ mã phiên cũng không suy ra được khoá.



Hình 2. Kiến trúc phân lớp của SecureVault Mobile

Lõi gồm 15 thành phần độc lập, mỗi thành phần một trách nhiệm: định dạng và nghiệp vụ kết; các nguyên hàm mật mã; giao diện trừu tượng của nguyên hàm; hai bản hiện thực mô-đun mã hoá nội dung; hai bản hiện thực mô-đun siêu dữ liệu; nghiệp vụ trên tệp; giấu tin; thuỷ vân; mã QR; các lớp bọc thư viện hệ thống; kiểu dữ liệu dùng chung; và lớp ứng dụng nối tất cả lại. Việc tách thành nhiều thành phần không nhằm cho “gọn” mà để chiều phụ thuộc trở thành thứ kiểm tra được bằng máy.

2.3. Ba quyết định kiến trúc then chốt

Phần này ghi lại ba quyết định có ảnh hưởng lớn nhất, kèm các phương án đã cân nhắc và lý do loại bỏ. Nhóm tác giả trình bày cả phương án bị loại vì đó mới là phần cho thấy quyết định được cân nhắc chứ không phải chọn ngẫu nhiên.

2.3.1. Đưa năng lực mật mã lên nền tảng di động

Bảng 5. Quyết định 1 — cách đưa mô-đun mã hoá nội dung lên di động

Phương án	Đánh giá	Kết luận
Đóng gói kèm tệp nhị phân của công cụ chuẩn và gọi như tiến trình con, giống bản máy tính	Không khả thi: iOS cấm sinh tiến trình; Android chặn thực thi tệp nhị phân nằm trong vùng lưu trữ mà ứng dụng ghi được	Loại
Viết lại toàn bộ nghiệp vụ cho di động bằng một định dạng tệp mới, đơn giản hơn	Khả thi về kỹ thuật nhưng phá vỡ tương thích: kết tạo trên máy tính không mở được trên điện thoại và ngược lại; đồng thời phải bảo trì hai bộ nghiệp vụ song song	Loại
Gọi thư viện mật mã của hệ điều hành Android	Buộc lỗi phụ thuộc vào nền tảng, mất khả năng dùng chung với bản máy tính và mất khả năng kiểm thử độc lập; định dạng tệp cũng khác đi	Loại
Đặt điểm nổi trù tượng tại mô-đun mã hoá nội dung, viết một bản hiện thực thuần Rust chạy trong tiến trình, giữ nguyên định dạng tệp	Nghiệp vụ, định dạng dữ liệu và hành vi của các lớp trên không đổi; hai nền tảng dùng chung một lõi; bản hiện thực mới kiểm chứng được bằng đối chứng với công cụ chuẩn	Chọn

2.3.2. Xử lý siêu dữ liệu

Bài toán tương tự lặp lại ở mô-đun siêu dữ liệu: bản máy tính gọi một công cụ ngoài dưới dạng tiến trình con, cách này không dùng được trên di động. Ba phương án được cân nhắc: (1) bỏ hẳn nhóm chức năng siêu dữ liệu trên bản di động — loại, vì đây là nhóm gắn trực tiếp với nguy cơ lộ toạ độ định vị, tức đúng thứ mà người dùng di động cần nhất; (2) gọi thư viện đọc ảnh của Android — loại, vì lõi sẽ phụ thuộc nền tảng và hành vi giữa hai bản không còn giống nhau; (3) tự viết một mô-đun thuần Rust, chạy trong tiến trình, phạm vi định dạng hẹp nhưng công bố rõ ràng — được chọn. Phương án 3 kèm một hệ quả phải xử lý đúng: phạm vi định dạng hẹp hơn bản

máy tính, nên giao diện phải phản ánh trung thực điều đó thay vì hứa hẹn quá khả năng (mục 3.7).

2.3.3. Bất biến định dạng tệp

Quyết định thứ ba là một ràng buộc tự đặt ra: *dù thay bản hiện thực nào bên dưới, định dạng tệp trên đĩa không được thay đổi*. Ràng buộc này khiến việc hiện thực khó hơn hẳn, nhưng nó bảo toàn ba giá trị: kết tạo trên máy tính mở được trên điện thoại và ngược lại; tệp tạo ra vẫn kiểm tra được bằng công cụ chuẩn của cộng đồng; và người dùng không bị khoá vào sản phẩm. Vì đây là ràng buộc dễ bị vi phạm âm thầm, nhóm tác giả không kiểm tra nó bằng lập luận mà bằng thực nghiệm đối chứng hai chiều (mục 5.4).

PHẦN III. GIẢI QUYẾT CÁC VẤN ĐỀ KỸ THUẬT

3.1. Rào cản tiến trình con trên nền tảng di động

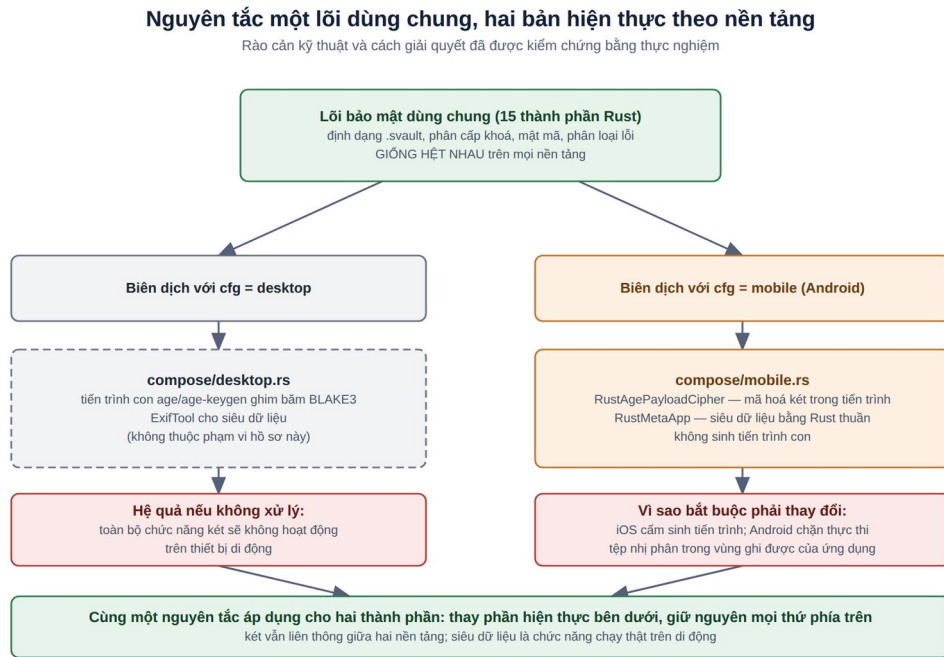
Đây là nội dung mang hàm lượng kỹ thuật cao nhất của sáng kiến, và cũng là lý do vì sao các công cụ mật mã mạnh hiện nay không có bản dùng được trên điện thoại — một sự thật dễ bị hiểu nhầm thành “chưa ai chịu làm”.

Các công cụ mật mã tin cậy được phân phối dưới dạng tệp nhị phân chạy độc lập. Trên máy tính để bàn, ứng dụng gọi chúng như một tiến trình con: nạp tệp nhị phân, truyền tham số, đọc kết quả. Trên thiết bị di động thì cơ chế này bị chặn ở hai tầng khác nhau: iOS cấm hoàn toàn việc một ứng dụng sinh tiến trình; Android cho phép sinh tiến trình nhưng chặn thực thi tệp nhị phân nằm trong vùng lưu trữ mà ứng dụng ghi được — tức đúng nơi mà một tệp nhị phân đóng gói kèm ứng dụng sẽ nằm.

Hệ quả rất cụ thể: mọi chức năng phụ thuộc tiến trình con sẽ không hoạt động trên điện thoại, *kể cả khi mã nguồn biên dịch thành công*. Đây là điểm khiến rào cản khó phát hiện sớm: chương trình dựng xong, cài được, mở được, và chỉ hỏng khi người dùng bấm vào chức năng. Vì vậy nhóm tác giả xác định đây là rào cản thuộc về kiến trúc nền tảng, phải giải quyết bằng thiết kế chứ không bằng công sức lập trình.

3.2. Điểm nối trừu tượng và hai bản hiện thực

Giải pháp là đặt *điểm nối trừu tượng* tại đúng những vị trí phụ thuộc nền tảng. Cụ thể: lỗi không gọi thẳng công cụ mã hoá, mà gọi qua một giao diện trừu tượng mô tả đúng ba việc cần làm — sinh cặp khoá, mã hoá, giải mã. Bên dưới giao diện đó có hai bản hiện thực: bản máy tính điều khiển công cụ chuẩn dưới dạng tiến trình con (có ghim giá trị băm của tệp nhị phân để phát hiện tráo đổi), và bản di động thực hiện toàn bộ phép mã hoá ngay trong tiến trình ứng dụng. Việc chọn bản nào diễn ra ở lớp lắp ráp ứng dụng, theo nền tảng biên dịch — lỗi hoàn toàn không biết mình đang chạy với bản nào.



Hình 3. Nguyên tắc một lõi dùng chung, hai bản hiện thực theo nền tảng

Điều đáng lưu ý về mặt thiết kế là *vị trí* của điểm nối. Đặt quá cao (ở mức nghiệp vụ) thì mỗi nền tảng phải viết lại toàn bộ nghiệp vụ; đặt quá thấp (ở mức từng phép mật mã) thì bản hiện thực phải tự ghép lại đúng định dạng tệp và rất dễ lệch. Điểm nối được đặt đúng ở ranh giới “một luồng dữ liệu vào, một luồng dữ liệu ra theo định dạng công khai”, nhờ vậy hai bản hiện thực khác nhau hoàn toàn về cách chạy nhưng buộc phải cho ra cùng một chuỗi byte.

Cùng nguyên tắc đó được áp dụng lần thứ hai cho mô-đun siêu dữ liệu, cho thấy đây là một khuôn mẫu giải quyết vấn đề chứ không phải một mẹo dùng một lần.

3.3. Định dạng tệp kết .svault do nhóm tác giả thiết kế

Két an toàn là một tệp duy nhất. Cấu trúc tệp gồm bốn phần nối tiếp: chuỗi nhận dạng và phiên bản định dạng; độ dài phần đầu; phần đầu tệp ở dạng có cấu trúc; phần nội dung đã mã hoá; và cuối cùng là chữ ký số. Ba quyết định thiết kế quan trọng nằm trong cấu trúc này:

- **Danh mục tệp nằm bên trong phần đã mã hoá, không nằm ở phần đầu.** Đây là điểm khác biệt so với cách làm thông thường. Nhiều định dạng đặt danh sách tệp ở phần đầu cho tiện đọc nhanh; hệ quả là người có tệp mà không có mật khẩu vẫn biết bên trong có những gì. Ở đây toàn bộ nội dung kết, kể cả danh mục, là một

luồng mã hoá duy nhất — kết đang khoá không tiết lộ tên tệp, kích thước hay cả số lượng tệp, chỉ lộ tổng độ dài bản mã.

- **Phần đầu tệp chỉ chứa khoá đã được bọc, không bao giờ chứa khoá ở dạng rõ.**

Các khoá bên trong được bọc bằng mã hoá có xác thực, với khoá bọc dẫn xuất riêng cho từng trường và ràng buộc theo mã định danh của kết.

- **Chữ ký phủ lên một “gốc ràng buộc” tính từ cả phần đầu lẫn phần nội dung.**

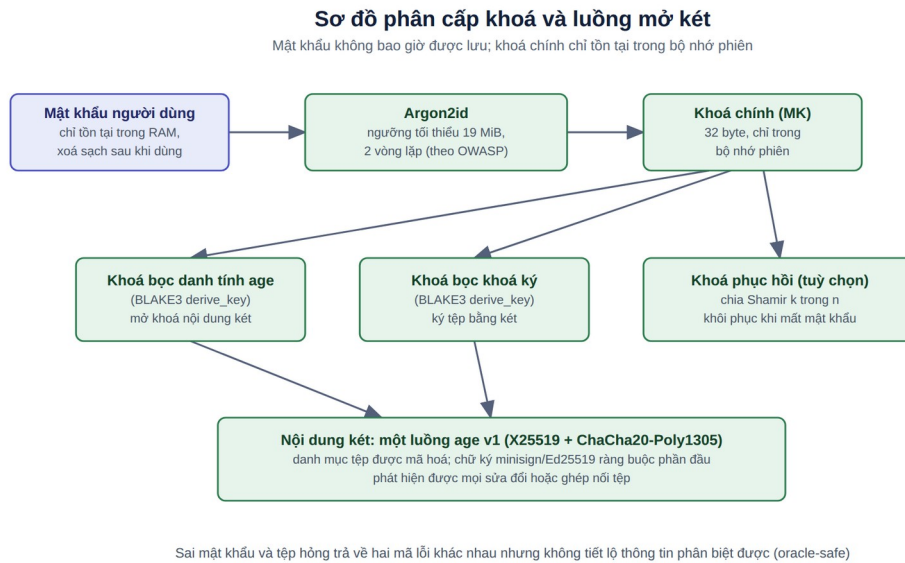
Nhờ vậy không thể ghép phần đầu của tệp này với phần nội dung của tệp khác: các giá trị băm của từng phần được tính lại khi đọc chứ không lưu sẵn trong tệp, nên tệp ghép sẽ cho gốc ràng buộc khác và chữ ký không còn hợp lệ.

Thứ tự kiểm tra khi mở kết cũng là một quyết định có chủ ý: kiểm tra chữ ký trước, rồi mới dẫn xuất khoá từ mật khẩu. Thứ tự này cho phép phân biệt rõ hai tình huống khác hẳn nhau — tệp hỏng hoặc bị sửa (phát hiện được mà chưa cần mật khẩu) và mật khẩu sai — mà không biến việc phân biệt đó thành manh mối dò mật khẩu, vì bước kiểm tra chữ ký diễn ra trước khi mật khẩu được dùng đến.

Ngoài ra, mọi thao tác ghi tệp đều theo kiểu nguyên tử: ghi ra tệp tạm rồi mới thay thế. Nếu quá trình ghi bị gián đoạn — hết pin, người dùng thoát ứng dụng — thì tệp kết cũ vẫn nguyên vẹn thay vì trở thành một tệp dở dang không mở được. Với một sản phẩm mà hỏng tệp đồng nghĩa mất dữ liệu vĩnh viễn, đây không phải chi tiết phụ.

3.4. Sơ đồ phân cấp khoá

Mật khẩu người dùng không được lưu ở bất kỳ đâu. Từ mật khẩu, hệ thống dẫn xuất khoá chính bằng Argon2id với tối thiểu 19 MiB bộ nhớ và 2 vòng lặp, theo ngưỡng khuyến nghị của OWASP. Tham số bộ nhớ quan trọng hơn số vòng lặp: nó là thứ làm cho việc dò mật khẩu hàng loạt bằng phần cứng chuyên dụng trở nên tốn kém. Ngưỡng được đặt ở mức vừa đủ để một điện thoại phổ thông vẫn mở kết trong thời gian chấp nhận được.



Hình 4. Sơ đồ phân cấp khoá và luồng mở kết

Khoá chính chỉ tồn tại trong bộ nhớ của phiên làm việc, không bao giờ chạm tới bộ nhớ lưu trữ. Từ khoá chính, hệ thống dẫn xuất các khoá con riêng cho từng mục đích, mỗi khoá con gắn với một *ngữ cảnh dẫn xuất* gồm ba thành phần: phiên bản bộ thuật toán, tên trường được bảo vệ, và mã định danh của kết. Cách ràng buộc này tạo ra hai tính chất đáng giá:

- Khoá bọc của một trường không dùng được cho trường khác — vì tên trường nằm trong ngữ cảnh, dẫn xuất sai ngữ cảnh sẽ ra khoá sai và phép kiểm tra xác thực thất bại.
- Khối dữ liệu đã bọc không thể mang từ kết này sang kết khác — vì mã định danh kết nằm trong ngữ cảnh.

Một hệ quả thực dụng của thiết kế này: *đổi mật khẩu không phải mã hoá lại toàn bộ nội dung*. Chỉ cần dẫn xuất khoá chính mới và bọc lại vài khoá con trong phần đầu tệp. Với một kết chứa nhiều tệp lớn trên điện thoại, khác biệt giữa vài mili-giây và vài phút là khác biệt giữa một chức năng người dùng thực sự dùng và một chức năng họ ngại dùng.

3.5. Lựa chọn nguyên hàm mật mã và tham số

Giải pháp không tự xây dựng thuật toán mật mã mới — một nguyên tắc nghề nghiệp cơ bản mà nhóm tác giả tuân thủ. Toàn bộ nguyên hàm đều là chuẩn đã công bố, được cộng đồng nghiên cứu và soi xét lâu dài. Đóng góp của nhóm tác giả nằm ở

việc chọn nguyên hàm nào cho việc gì, ghép chúng lại trong một kiến trúc, và đặt tham số phù hợp với ràng buộc của thiết bị di động.

Bảng 6. Các thuật toán và cơ chế mật mã được lựa chọn

Chức năng trong thiết kế	Nguyên hàm được chọn	Lý do lựa chọn
Dẫn xuất khoá từ mật khẩu	Argon2id	Chống dò mật khẩu bằng phần cứng chuyên dụng; đặt ngưỡng 19 MiB / 2 vòng theo khuyến nghị OWASP, cân bằng giữa độ khó dò và thời gian mở kết trên điện thoại phổ thông
Băm nội dung và tạo khoá con	BLAKE3	Tốc độ xử lý cao, phù hợp thiết bị di động; hỗ trợ sẵn cơ chế dẫn xuất khoá theo ngữ cảnh — chính là cơ chế dùng để ràng buộc khoá con theo trường và theo kết
Mã hoá nội dung kết	age v1 (X25519 + ChaCha20-Poly1305)	Định dạng công khai, có đặc tả rõ ràng và công cụ chuẩn để đối chứng; đồng thời cung cấp cả mã hoá lẫn kiểm tra toàn vẹn
Bảo vệ các trường khoá trong phần đầu tệp	XSalsa20-Poly1305 (libsodium secretbox)	Cơ chế mã hoá kèm xác thực đã được dùng rộng rãi, phù hợp để bảo vệ các khối dữ liệu khoá kích thước nhỏ
Bảo vệ phần đầu tệp bằng chữ ký số	Ed25519 (định dạng minisign)	Chữ ký kích thước nhỏ, xác minh nhanh, và ở định dạng có công cụ tương thích để bên thứ ba tự kiểm tra
Chia khoá phục hồi	Shamir k-trong-n (sss hazmat.c)	Chia khoá thành nhiều phần với ngưỡng khôi phục; dưới ngưỡng thì các mảnh không tiết lộ gì về bí mật

3.6. Quy tắc phân loại lỗi an toàn

Thông báo lỗi là một kênh rò rỉ thông tin thường bị bỏ qua. Nếu ứng dụng báo “sai mật khẩu” trong một trường hợp và “tệp hỏng” trong trường hợp khác, thì chính sự khác nhau đó trở thành công cụ để người tấn công dò dần. Nhóm tác giả xử lý bằng cách tách hẳn hai tầng: lỗi bên trong phân biệt các nguyên nhân lỗi rất chi tiết để lập trình viên gỡ lỗi được; nhưng khi vượt qua ranh giới ra giao diện, các nguyên nhân được chiếu về một tập lỗi hẹp hơn theo quy tắc cố định.

Bảng 7. Quy tắc chiếu lỗi từ lỗi ra giao diện

Tình huống bên trong lỗi	Lỗi hiển thị cho người dùng	Lý do
Sai mật khẩu; hoặc đủ số mảnh khôi phục nhưng mảnh không đúng	Không đủ điều kiện truy cập	Hợp nhất hai trường hợp để chênh lệch thông báo không dùng làm tín hiệu dò
Thiếu mảnh khôi phục so với ngưỡng	Thiếu mảnh: đã có k, cần n	Đây là thông tin không bí mật và người dùng cần biết để bổ sung mảnh
Không phải tệp của ứng dụng (sai chuỗi nhận dạng, tệp cắt, cấu trúc hỏng)	Không phải tệp Secure Vault	Tình huống lành tính, không liên quan đến bí mật; tách riêng để người dùng không hiểu nhầm là dữ liệu bị hỏng
Đúng là tệp của ứng dụng nhưng chữ ký không hợp lệ	Tệp bị hỏng hoặc đã bị sửa	Phát hiện trước khi mật khẩu được dùng đến, nên không phải tín hiệu về mật khẩu
Sai phiên bản định dạng	Phiên bản định dạng không tương thích, kèm số phiên bản	Thông tin không bí mật và giúp người dùng biết cần bản ứng dụng nào
Lỗi vào/ra hệ thống (thiếu quyền, đầy bộ nhớ, đường dẫn sai)	Lỗi đọc/ghi tệp, mô tả cố định	Thông điệp gốc của hệ thống có thể chứa đường dẫn, nên thay bằng mô tả cố định
Lỗi nội bộ ngoài dự kiến	Lỗi nội bộ	Không mô tả chi tiết trạng thái bên trong ra ngoài

Điểm cần nhấn mạnh: quy tắc này áp dụng thống nhất cho cả hai bản hiện thực của mô-đun mã hoá. Nếu bản di động và bản máy tính báo lỗi khác nhau trong cùng một tình huống thì chính sự khác nhau đó lại thành kênh rò rỉ mới — nên đây là một trong những nội dung được kiểm thử riêng.

3.7. Mô-đun xử lý siêu dữ liệu thuần Rust

Ảnh chụp bằng điện thoại thường mang theo toạ độ GPS, kiểu thiết bị, thời điểm chụp và nhiều thông tin khác. Những dữ liệu này đi kèm tệp mà người dùng không nhận biết — một kênh lộ thông tin nằm ngoài nội dung. Bản máy tính xử lý nhóm này bằng cách gọi một công cụ ngoài; trên di động, cách đó vướng đúng rào cản ở mục 3.1, nên nhóm tác giả tự viết một mô-đun thuần Rust chạy trong tiến trình.

Mô-đun này nhận dạng định dạng từ các byte đầu tệp chứ không từ phần mở rộng — vì phần mở rộng do người dùng đặt và có thể sai. Phạm vi hiện tại: đọc và liệt kê thẻ siêu dữ liệu với JPEG, PNG, TIFF, WebP và HEIF; xoá siêu dữ liệu với JPEG và PNG. Với định dạng nằm ngoài phạm vi xoá, mô-đun từ chối kèm mã lỗi thay vì trả về thành công.

Nguyên tắc “mặc định đóng” và cách giao diện phản ánh phạm vi thật

Khi khởi động, giao diện hỏi lỗi xem mô-đun siêu dữ liệu có sẵn sàng không. Nếu không, ba màn hình liên quan bị vô hiệu hoá kèm cảnh báo, thay vì để người dùng bấm rồi nhận lỗi giữa chừng.

Phạm vi định dạng công bố trên giao diện được điều chỉnh theo nền tảng đang chạy, để bản di động không quảng cáo những định dạng mà mô-đun của nó không xử lý được. Một giao diện hứa nhiều hơn khả năng thật là một lỗi an toàn, không phải lỗi trình bày: người dùng sẽ tin rằng ảnh đã sạch trong khi nó chưa sạch.

Chức năng xoá luôn tạo tệp kết quả mới và giữ nguyên tệp gốc, đồng thời báo số thẻ trước và sau khi xử lý. Kèm theo đó là chức năng so sánh siêu dữ liệu hai tệp, để người dùng *tự kiểm tra* kết quả thay vì chỉ tin vào thông báo của ứng dụng — cùng một tinh thần “kiểm chứng được” áp dụng ở mức thao tác hằng ngày.

3.8. Luồng xử lý tệp trên Android

Android giới hạn quyền truy cập trực tiếp của ứng dụng vào bộ nhớ thiết bị. Người dùng chọn tệp qua bộ chọn của hệ điều hành, và ứng dụng chỉ nhận được quyền với đúng tệp được chọn. Lỗi nghiệp vụ lại được xây dựng quanh khái niệm đường dẫn tệp thông thường. Có hai cách nối hai thứ này: sửa lỗi để làm việc với luồng dữ liệu của Android, hoặc để lớp nền tảng chịu trách nhiệm quy đổi. Nhóm tác giả chọn cách thứ hai: ứng dụng sao chép tệp được chọn vào vùng lưu trữ riêng, xử lý, ghi kết quả ra vị trí người dùng chọn, rồi xoá dữ liệu tạm.



Ranh giới tin cậy: toàn bộ khối trên nằm trong vùng lưu trữ riêng của ứng dụng, được hệ điều hành cách ly và mã hoá ở mức tệp (File-Based Encryption).

Ứng dụng **KHÔNG** khai báo quyền truy cập mạng (INTERNET).

Điểm cần ghi nhận trung thực: bản sao tạm ở dạng rõ tồn tại trong vùng đệm trong thời gian thao tác — đã được ghi nhận trong mô hình mối đe dọa.

Hình 5. Luồng xử lý tệp trên Android

Lý do của lựa chọn: giữ nguyên giao diện dữ liệu của lỗi, nhờ đó toàn bộ nghiệp vụ đã xây dựng và kiểm thử cho môi trường máy tính dùng lại được nguyên vẹn, và cơ chế quyền truy cập tệp của Android được tách hẳn khỏi phần xử lý bên trong.

3.9. Mô hình phiên làm việc và vòng đời bí mật

Khi mở kết, ứng dụng không trả khoá về cho giao diện. Thay vào đó nó tạo một *phiên làm việc*: khoá chính nằm trong bộ nhớ của lỗi, còn giao diện chỉ nhận một mã phiên ngẫu nhiên. Mọi thao tác về sau tham chiếu qua mã phiên đó. Thiết kế này có ba hệ quả:

- Bí mật không đi qua ranh giới giữa lỗi và giao diện nhiều lần, nên vùng có thể rò rỉ thu hẹp lại.
- Mã phiên không mang thông tin bí mật nên kể cả khi lộ cũng không dùng để suy ra khoá.
- Thao tác “khóa kết” trở thành một hành động dứt khoát: xoá mục phiên khỏi bộ nhớ, khoá chính bị xoá theo, và muốn mở lại phải nhập mật khẩu.

Đi cùng với đó, mật khẩu khi truyền qua các lớp được bọc trong kiểu dữ liệu tự xoá nội dung khi hết phạm vi sử dụng, để bản sao của mật khẩu không nằm lại trong bộ nhớ lâu hơn mức cần thiết.

PHẦN IV. SẢN PHẨM: CHỨC NĂNG VÀ GIAO DIỆN

Ứng dụng cung cấp 38 chức năng nghiệp vụ, phân thành tám nhóm theo mục đích sử dụng, thao tác qua 21 màn hình giao diện. Với mỗi nhóm, tài liệu trình bày ba lớp thông tin: nhóm này giải quyết việc gì; từng chức năng nhận đầu vào nào, xử lý ra sao, cho kết quả gì; và giao diện nào thực hiện nhóm chức năng đó, kèm mã màn hình để đối chiếu với ảnh chụp ở Phụ lục B. Cách trình bày này cho phép kiểm tra trực tiếp giữa chức năng được mô tả và giao diện có thật, thay vì phải tin vào lời mô tả.

4.1. Tám nhóm chức năng

Nhóm 1. Két an toàn

Két an toàn là một tệp duy nhất có phần mở rộng .svault, hoạt động như một kho chứa được bảo vệ bằng mật khẩu. Bên trong két có thể lưu nhiều tệp cùng thông tin danh mục; toàn bộ nội dung và danh mục đều được mã hóa. Nhờ đó, người dùng chỉ cần quản lý một mật khẩu cho cả két, đồng thời người có tệp két nhưng không có mật khẩu không thể xem nội dung hoặc tên các tệp bên trong.

Bảng 8. Các chức năng của nhóm 1

Chức năng	Đầu vào	Xử lý	Kết quả
Tạo két mới	Vị trí lưu, mật khẩu, tùy chọn chính sách phục hồi khóa	Sinh khoá chính từ mật khẩu bằng Argon2id; sinh cặp khoá nội dung và cặp khoá ký riêng cho két; Ghi tệp theo cơ chế an toàn, bảo đảm tệp cũ không bị thay đổi nếu quá trình ghi bị gián đoạn.	Tệp .svault mới kèm thông tin tóm tắt của két
Mở két	Tệp két, mật khẩu	Kiểm tra tính hợp lệ của tệp, sau đó xác thực mật khẩu và mở nội dung	Mã phiên làm việc để thực hiện các thao tác trên két
Khoá két	Mã phiên	Xoá khoá chính khỏi bộ nhớ phiên	Phiên kết thúc; muốn mở lại phải nhập mật khẩu
Đổi mật khẩu két	Mã phiên, mật khẩu mới	Tạo khoá chính mới và bảo vệ lại các khóa bên trong; không cần mã hóa lại toàn bộ nội dung	Két sử dụng mật khẩu mới; dữ liệu bên trong không thay đổi
Xem thông tin két	Mã phiên	Đọc và xác thực thông tin phần đầu tệp	Mã định danh két, phiên bản định dạng, thời điểm tạo và sửa,

			số tệp bên trong, chính sách khoá phục hồi
Thêm tệp vào kết	Mã phiên, tệp nguồn, tên đặt trong kết	Mã hóa và bổ sung tệp vào danh mục của kết	Tệp được lưu trong kết; tệp gốc bên ngoài không bị thay đổi
Liệt kê tệp trong kết	Mã phiên	Đọc danh mục tệp đã giải mã trong bộ nhớ	Danh sách tên tệp, kích thước và thời điểm thêm
Trích xuất tệp khỏi kết	Mã phiên, tên tệp trong kết, nơi lưu	Giải mã và ghi ra tệp mới	Tệp được khôi phục từ kết
Ký tệp bằng kết	Mã phiên, tệp cần ký	Sử dụng khoá ký riêng của kết để tạo chữ ký số	Tệp chữ ký để kiểm tra nguồn gốc và tính toàn vẹn của tệp
Xuất khoá công khai của kết	Mã phiên	Đọc khoá công khai từ thông tin của kết	Khóa công khai để kiểm tra chữ ký do kết tạo
Kiểm tra tính toàn vẹn của kết	Tệp kết (không cần mật khẩu)	Kiểm tra chữ ký bảo vệ phần thông tin đầu tệp	Kết luận tệp còn nguyên vẹn hay đã bị thay đổi, không cần mở kết
Lấy vân tay tệp kết	Tệp kết	Tính giá trị băm BLAKE3 của toàn bộ tệp	Chuỗi vân tay để đối chiếu tệp giữa các thiết bị

Giao diện tương ứng

Toàn bộ chức năng của kết được bố trí trên một màn hình (GD03), với hai trạng thái rõ ràng: chưa mở kết và đang mở kết. Cách tổ chức này giúp trạng thái khóa/mở của kết luôn được thể hiện trực quan, đồng thời hạn chế nhầm lẫn trong quá trình sử dụng.

Khi chưa mở kết, giao diện tập trung vào các thao tác chính gồm mở kết, tạo kết mới và nhóm các chức năng phục hồi, kiểm tra tệp trong mục mở rộng. Khi tạo kết, thiết lập khóa phục hồi được đặt trong phần tùy chọn mở rộng, kèm ví dụ minh họa như “5 mảnh, cần 3”, giúp người dùng dễ hiểu cơ chế phục hồi.

Khi kết đang mở, giao diện chuyển sang bảng điều khiển gồm thông tin kết, danh sách tệp và các chức năng thêm, trích xuất, ký tệp, xuất khóa công khai, tạo mảnh phục hồi và đổi mật khẩu. Nút “Khóa” được đặt ngay cạnh tên kết để thao tác kết thúc phiên luôn được hiển thị rõ ràng.

Bảng 9. Màn hình giao diện của nhóm 1

Mã màn hình	Tên màn hình	Chức năng được thực hiện
GD03	Kết an toàn	vault_create, vault_unlock,

		vault_lock, vault_change_passphrase, vault_meta, item_add, item_list, item_extract, sign_file, export_signing_public_key, integrity_check, integrity_hash, keys_split, keys_recover, verify_file
--	--	--

Nhóm 2. Bảo vệ tệp đơn lẻ

Không phải trường hợp nào cũng cần sử dụng kết an toàn. Khi chỉ cần bảo vệ một tệp riêng lẻ để lưu trữ hoặc chuyển giao, người dùng có thể khóa trực tiếp tệp bằng mật khẩu. Tệp kết quả chứa đầy đủ thông tin cần thiết để thực hiện quá trình mở khóa trên thiết bị hoặc công cụ tương thích khi có đúng mật khẩu.

Bảng 10. Các chức năng của nhóm 2

Chức năng	Đầu vào	Xử lý	Kết quả
Khoá một tệp bằng mật khẩu	Tệp cần khóa, mật khẩu, vị trí lưu kết quả	Dẫn xuất khoá từ mật khẩu bằng Argon2id rồi mã hoá có xác thực	Tệp đã khóa; mọi thay đổi đối với nội dung đều được phát hiện khi mở khóa
Mở khoá tệp	Tệp đã khóa, mật khẩu, vị trí lưu kết quả	Dẫn xuất lại khoá và giải mã, đồng thời kiểm tra tính toàn vẹn	Tệp gốc được khôi phục nếu thông tin hợp lệ; thông báo lỗi nếu mật khẩu không đúng hoặc tệp bị thay đổi
Sao chép tệp an toàn	Tệp gốc, vị trí lưu	Sao chép tệp và kiểm tra kết quả sau khi sao chép	Bản sao được kiểm tra, sử dụng cho các bước xử lý tiếp theo mà không làm thay đổi tệp gốc

Giao diện tương ứng

Hai màn hình GD04 và GD05 được thiết kế theo quy trình ba bước có đánh số: (1) chọn tệp nguồn, (2) chọn vị trí lưu kết quả, (3) nhập mật khẩu, sau đó thực hiện thao tác bằng một nút chức năng chính. Cách đánh số giúp người dùng dễ theo dõi trình tự và kiểm tra các thông tin cần thiết trước khi thực hiện.

Ô mật khẩu khi tạo tệp có thêm trường nhập lại để hạn chế lỗi nhập sai. Các thông tin kỹ thuật như Argon2id và secretbox được đặt trong mục “Thông tin thêm”, tránh làm giao diện chính quá phức tạp. Kết quả xử lý được hiển thị trong một thẻ riêng và

được xóa khi chuyển màn hình, giúp tránh nhầm lẫn giữa kết quả của các thao tác khác nhau.

Bảng 11. Màn hình giao diện của nhóm 2

Mã màn hình	Tên màn hình	Chức năng được thực hiện
GD04	Khoá tệp	crypto_encrypt_file
GD05	Mở khoá tệp	crypto_decrypt_file, copy_file

Nhóm 3. Kiểm chứng nguồn gốc và tính toàn vẹn

Mã hóa giúp bảo vệ nội dung tệp khỏi việc đọc trái phép, trong khi nhóm chức năng này tập trung kiểm tra nguồn gốc và tính toàn vẹn của tệp. Chữ ký số giúp xác minh tệp có đúng do người ký tạo hoặc xác nhận hay không; giá trị băm giúp đối chiếu xem tệp có bị thay đổi so với bản được cung cấp ban đầu hay không. Đây là các chức năng cần thiết khi trao đổi và kiểm tra tài liệu.

Bảng 12. Các chức năng của nhóm 3

Chức năng	Đầu vào	Xử lý	Kết quả
Tạo cặp khoá ký	Thư mục lưu, tên định danh, mật khẩu bảo vệ khoá bí mật	Sinh cặp khoá Ed25519; khoá bí mật được bảo vệ bằng mật khẩu	Tập khoá công khai để chia sẻ và tập khoá bí mật để giữ riêng
Ký một tệp	Tệp cần ký, khoá bí mật, mật khẩu	Tạo chữ ký số theo định dạng minisign	Tệp chữ ký đi kèm tệp gốc
Kiểm tra chữ ký	Tệp, tệp chữ ký, khoá công khai của người ký	Xác minh chữ ký trên nội dung tệp	Kết luận chữ ký hợp lệ hoặc không hợp lệ; mọi thay đổi nội dung sau khi ký đều làm chữ ký không còn hợp lệ
Lấy vân tay tệp	Tệp bất kỳ	Tính giá trị băm BLAKE3	Chuỗi vân tay dùng để đối chiếu hai bản sao của cùng một tệp
Đối chiếu tệp với vân tay cho trước	Tệp, chuỗi vân tay nhận được	Tính lại giá trị băm và so sánh với vân tay đã cung cấp	Kết luận tệp có khớp với vân tay được cung cấp hay không
Xác minh tệp tải về	Tệp, vân tay và/hoặc chữ ký kèm khoá công khai	Kiểm tra các bằng chứng được cung cấp	Kết luận đạt/không đạt, tránh phải dùng nhiều công cụ rời rạc

Giao diện tương ứng

Nhóm chức năng này gồm năm màn hình (GD06–GD10), được phân chia theo mục đích sử dụng. Mặc dù các chức năng đều sử dụng chữ ký số hoặc hàm băm, mỗi

màn hình phục vụ một thao tác riêng như tạo khóa ký, ký tệp, kiểm tra chữ ký, lấy vân tay, đối chiếu vân tay và xác minh tệp tải về. Cách tổ chức này giúp người dùng lựa chọn đúng chức năng theo nhu cầu thực tế.

Màn hình Ký tệp (GD06) bố trí việc tạo cặp khóa ký và ký tệp theo trình tự, bảo đảm người dùng có khóa bí mật trước khi thực hiện ký. Màn hình Xác minh tệp tải về (GD10) cho phép sử dụng vân tay, chữ ký kèm khóa công khai hoặc đồng thời cả hai loại bằng chứng; các trường không bắt buộc được đánh dấu rõ ràng là “(tùy chọn)”. Kết quả kiểm tra được thể hiện bằng thẻ kết quả có cả màu sắc và tiêu đề chữ, giúp người dùng nhận biết rõ trạng thái đạt/không đạt.

Bảng 13. Màn hình giao diện của nhóm 3

Mã màn hình	Tên màn hình	Chức năng được thực hiện
GD06	Ký tệp	crypto_generate_signing_keypair, crypto_sign_file
GD07	Kiểm tra chữ ký	integrity_verify_signature
GD08	Lấy vân tay tệp	integrity_hash_file
GD09	Kiểm tra tệp chưa bị đổi	integrity_hash_file
GD10	Xác minh tệp tải về	integrity_verify_integrity

Nhóm 4. Sao lưu và khôi phục bằng chia sẻ bí mật theo ngưỡng

Do ứng dụng không lưu mật khẩu và khóa bí mật lâu dài, việc quên mật khẩu có thể dẫn đến mất khả năng truy cập dữ liệu. Nhóm chức năng này sử dụng cơ chế chia sẻ bí mật Shamir, cho phép chia một bí mật thành nhiều phần và quy định số phần tối thiểu cần có để khôi phục. Ví dụ, với cấu hình “5 mảnh, cần 3”, bất kỳ 3 trong 5 mảnh đều có thể được sử dụng để khôi phục. Khi chưa đủ số mảnh theo ngưỡng, bí mật không thể được khôi phục.

Bảng 14. Các chức năng của nhóm 4

Chức năng	Đầu vào	Xử lý	Kết quả
Chia một bí mật thành nhiều mảnh	Chuỗi bí mật (mật khẩu, khóa, cụm từ khôi phục), tổng số mảnh n, ngưỡng khôi phục k	Sinh khóa ngẫu nhiên, sử dụng cơ chế Shamir để chia bí mật và bảo vệ dữ liệu liên quan bằng khóa đó	Các tệp mảnh và tệp dữ liệu cần thiết để khôi phục; phải có đủ số mảnh theo ngưỡng
Chia một tệp thành nhiều mảnh	Tệp bất kỳ, tổng số mảnh, ngưỡng	Bảo vệ nội dung tệp, sau đó chia khóa bảo vệ theo cơ chế Shamir	Các tệp mảnh và tệp dữ liệu cần thiết để khôi phục tệp
Khôi phục từ các mảnh	Đủ số mảnh theo ngưỡng, tệp dữ liệu cần khôi phục	Ghép khóa từ các mảnh và sử dụng khóa đó để khôi phục	Bí mật hoặc tệp ban đầu; nếu chưa đủ mảnh, hệ thống thông

		dữ liệu	báo số mảnh còn thiếu
Tạo mảnh khôi phục cho kết	Mã phiên của kết đang mở, tổng số mảnh, ngưỡng	Chia khoá dự phòng của kết theo Shamir	Các mảnh dùng để khôi phục quyền truy cập kết khi không còn mật khẩu
Khôi phục kết từ các mảnh	Tập kết, đủ số mảnh theo ngưỡng	Khôi phục khóa từ các mảnh và sử dụng khóa đó để mở kết	Phiên làm việc được mở mà không cần mật khẩu ban đầu
Xuất mảnh ra mã QR	Các chuỗi mảnh	Sinh ảnh mã QR cho từng mảnh	Ảnh mã QR có thể in hoặc chuyển sang thiết bị khác
Khôi phục từ ảnh mã QR	Đủ số ảnh QR theo ngưỡng, tệp dữ liệu cần khôi phục	Đọc dữ liệu từ các mã QR, sau đó thực hiện khôi phục như đối với các mảnh thông thường	Bí mật hoặc tệp ban đầu

Giao diện tương ứng

Nhóm chức năng này gồm bốn màn hình (GD11–GD14), tương ứng với các thao tác chính: chia một bí mật, chia một tệp, khôi phục từ các mảnh và chuyển mảnh bằng mã QR.

Tại các màn hình chia, tổng số mảnh và số mảnh tối thiểu để khôi phục được nhập riêng và có giá trị mặc định phù hợp. Giao diện sử dụng cách diễn đạt bằng lời thay cho ký hiệu k, n , đồng thời minh họa cụ thể như “5 mảnh, cần 3 → bất kỳ 3 trong 5 mảnh đều có thể khôi phục” để hạn chế nhầm lẫn khi thiết lập.

Sau khi chia, các mảnh được hiển thị thành danh sách để người dùng sao chép; thông tin về tệp dữ liệu cần thiết cho quá trình khôi phục cũng được hiển thị riêng. Dữ liệu bí mật đầu vào được xóa khỏi ô nhập sau khi xử lý, đồng thời danh sách mảnh được xóa khi chuyển sang chức năng khác, hạn chế việc thông tin nhạy cảm còn hiển thị trên màn hình.

Màn hình khôi phục (GD13) cho phép nhập mảnh bằng cách chọn tệp hoặc dán trực tiếp chuỗi mảnh. Khi chưa đủ số mảnh theo ngưỡng, hệ thống thông báo số mảnh còn thiếu để người dùng bổ sung trước khi thực hiện khôi phục.

Bảng 15. Màn hình giao diện của nhóm 4

Mã màn hình	Tên màn hình	Chức năng được thực hiện
GD11	Chia nhỏ bí mật	shares_split_secret
GD12	Chia nhỏ tệp	shares_split_file
GD13	Ghép lại từ các mảnh	shares_recover_secret, copy_

		file
GD14	Chuyển mảnh bằng mã QR	shares_export_qr, shares_recover_from_qr

Nhóm 5. Che giấu dữ liệu trong ảnh và phát hiện dữ liệu ẩn

Che giấu dữ liệu không thay thế cho mã hóa mà được sử dụng như một lớp bổ sung. Dữ liệu được mã hóa trước khi nhúng vào ảnh, do đó nếu dữ liệu ẩn bị phát hiện thì nội dung vẫn cần mật khẩu để giải mã. Chức năng phát hiện dữ liệu ẩn giúp người dùng nhận biết rằng kỹ thuật che giấu không bảo đảm dữ liệu không bị phát hiện, qua đó làm rõ giới hạn của phương pháp trong quá trình sử dụng và huấn luyện.

Bảng 16. Các chức năng của nhóm 5

Chức năng	Đầu vào	Xử lý	Kết quả
Giấu dữ liệu vào ảnh	Ảnh nền, tệp cần giấu, mật khẩu, tùy chọn phân tán dữ liệu	Mã hoá tệp trước, sau đó nhúng vào các bit ít quan trọng của ảnh	Ảnh mới nhìn bằng mắt không khác ảnh gốc, mang dữ liệu đã mã hoá bên trong
Lấy dữ liệu đã giấu ra	Ảnh có dữ liệu ẩn, mật khẩu, thư mục lưu	Trích các bit ẩn rồi giải mã	Tệp ban đầu, giữ nguyên tên và phần mở rộng
Phát hiện dấu hiệu dữ liệu ẩn	Ảnh bất kỳ	Phân tích dữ liệu thừa sau điểm kết thúc ảnh và thống kê bit ít quan trọng	Mức độ nghi ngờ kèm giải thích về các dấu hiệu được phát hiện; kết quả không phát hiện không đồng nghĩa với việc khẳng định ảnh không chứa dữ liệu ẩn

Giao diện tương ứng

Ba màn hình GD15–GD17 tương ứng với ba thao tác: giấu dữ liệu, lấy dữ liệu và phát hiện dữ liệu ẩn. Cách bố trí này giúp người dùng phân biệt rõ chức năng che giấu với chức năng kiểm tra, đồng thời thể hiện giới hạn của kỹ thuật che giấu dữ liệu.

Màn hình Giấu dữ liệu (GD15) yêu cầu lựa chọn ảnh nền, tệp cần giấu, mật khẩu và vị trí lưu kết quả. Phần “Thông tin thêm” giải thích thứ tự xử lý: dữ liệu được mã hóa trước khi nhúng vào ảnh và thông tin về định dạng tệp đầu ra.

Màn hình Phát hiện dữ liệu ẩn (GD17) không đưa ra kết luận tuyệt đối về việc ảnh có chứa dữ liệu ẩn hay không. Kết quả được thể hiện dưới dạng mức độ nghi ngờ kèm các dấu hiệu được phát hiện, đồng thời giải thích rõ rằng việc không phát hiện dấu

hiệu qua các phép kiểm tra không đồng nghĩa với việc ảnh hoàn toàn không chứa dữ liệu ẩn. Cách thể hiện này giúp người dùng hiểu đúng giới hạn của công cụ và tránh diễn giải kết quả theo hướng tuyệt đối.

Bảng 17. Màn hình giao diện của nhóm 5

Mã màn hình	Tên màn hình	Chức năng được thực hiện
GD15	Giấu dữ liệu trong ảnh	stego_hide
GD16	Hiện dữ liệu ẩn	stego_extract, copy_file
GD17	Phát hiện dữ liệu ẩn	stego_detect

Nhóm 6. Thủy vân chống giả mạo ảnh

“Thủy vân dễ vỡ” (fragile watermark) là một dấu hiệu vô hình được gắn với mật khẩu và nhúng vào ảnh. Khi ảnh bị chỉnh sửa, thủy vân có thể bị phá vỡ, qua đó giúp kiểm tra tính toàn vẹn của ảnh và xác định các vùng có dấu hiệu bị thay đổi. Khác với chữ ký số chủ yếu cho biết tệp có còn nguyên vẹn hay không, thủy vân còn hỗ trợ khoanh vùng vị trí thay đổi trên ảnh.

Bảng 18. Các chức năng của nhóm 6

Chức năng	Đầu vào	Xử lý	Kết quả
Nhúng thủy vân	Ảnh PNG hoặc BMP, mật khẩu, nơi lưu	Tính mã xác thực theo từng khối ảnh, khoá bằng mật khẩu, nhúng vào bit ít quan trọng	Ảnh đã được nhúng thủy vân; tệp ảnh gốc không bị thay đổi
Kiểm tra thủy vân	Ảnh đã nhúng thủy vân, mật khẩu	Tính lại mã xác thực theo từng khối và đối chiếu với thông tin thủy vân	Kết luận ảnh còn nguyên vẹn hay đã bị sửa, kèm vị trí các vùng bị thay đổi

Giao diện tương ứng

Màn hình GD18 tích hợp hai thao tác nhúng thủy vân và kiểm tra thủy vân trên cùng một giao diện. Hai thao tác sử dụng chung cơ chế bảo vệ bằng mật khẩu và thường được thực hiện liên tiếp trong quá trình kiểm tra ảnh.

Phần “Thông tin thêm” nêu rõ các điều kiện ảnh hưởng đến kết quả kiểm tra: độ an toàn của thủy vân phụ thuộc vào mật khẩu được sử dụng; ảnh cần được lưu ở định dạng không mất dữ liệu như PNG hoặc BMP. Việc chuyển sang JPEG hoặc thay đổi kích thước ảnh có thể làm thủy vân không còn hợp lệ. Khi kiểm tra không đạt, giao

diện đồng thời lưu ý khả năng ảnh đã bị chỉnh sửa hoặc đã bị biến đổi trong quá trình lưu trữ, giúp người dùng tránh đồng nhất hai trường hợp này.

Bảng 19. Màn hình giao diện của nhóm 6

Mã màn hình	Tên màn hình	Chức năng được thực hiện
GD18	Chống giả mạo ảnh	watermark_embed, watermark_verify

Nhóm 7. Siêu dữ liệu ẩn trong tệp

Ảnh chụp bằng điện thoại có thể chứa các thông tin như tọa độ GPS, kiểu thiết bị, thời điểm chụp và một số thông tin khác. Những dữ liệu này có thể được chia sẻ cùng tệp ảnh mà người dùng không nhận biết. Nhóm chức năng này cho phép xem, xóa và đối chiếu siêu dữ liệu trực tiếp trên thiết bị, giúp người dùng kiểm tra và loại bỏ những thông tin không cần thiết trước khi chia sẻ tệp.

Bảng 20. Các chức năng của nhóm 7

Chức năng	Đầu vào	Xử lý	Kết quả
Xem siêu dữ liệu của tệp	Tệp ảnh	Đọc và nhóm các thẻ theo loại; nhóm tọa độ GPS được tách riêng vì nhạy cảm nhất	Danh sách thẻ theo nhóm kèm định dạng và kiểu MIME; thao tác chỉ đọc, không sửa tệp
Xóa siêu dữ liệu	Tệp ảnh, nơi lưu bản sạch	Dựng lại tệp từ dữ liệu ảnh, loại bỏ khối EXIF, hồ sơ màu, chú thích và các khối văn bản; ghi theo kiểu nguyên tử	Bản sao đã sạch siêu dữ liệu; tệp gốc giữ nguyên; báo cáo số thẻ trước và sau
So sánh siêu dữ liệu hai tệp	Hai tệp ảnh	Đối chiếu tập thẻ của hai tệp, bỏ qua tên tệp và dấu thời gian của hệ thống	Danh sách thẻ chỉ có ở tệp thứ nhất, chỉ có ở tệp thứ hai, và các thẻ khác giá trị
Kiểm tra mô-đun sẵn sàng	Không có	Kiểm tra và báo trạng thái sẵn sàng của mô-đun cho giao diện	Giao diện biết trạng thái để bật hoặc vô hiệu hóa các chức năng tương ứng

Giao diện tương ứng

Ba màn hình GD19–GD21 tương ứng với ba nghiệp vụ xem, xóa và so sánh siêu dữ liệu. Khi khởi động, giao diện kiểm tra trạng thái sẵn sàng của mô-đun siêu dữ liệu; nếu mô-đun không sẵn sàng, các chức năng liên quan được vô hiệu hóa và hiển thị cảnh báo. Cách tổ chức này thực hiện nguyên tắc “mặc định đóng”: khi chưa xác nhận

được thành phần xử lý sẵn sàng, hệ thống không cho phép thực hiện chức năng phụ thuộc vào thành phần đó.

Trên Android, mô-đun siêu dữ liệu được triển khai bằng Rust nên phạm vi định dạng được hỗ trợ được xác định rõ theo phiên bản đang chạy. Giao diện công bố cụ thể các định dạng được xử lý và các định dạng được hỗ trợ xóa siêu dữ liệu; định dạng ngoài phạm vi bị từ chối với thông báo lỗi có mã. Cách thể hiện này bảo đảm giao diện phản ánh đúng khả năng thực tế của mô-đun, tránh tạo kỳ vọng vượt quá phạm vi xử lý.

Màn hình Xóa siêu dữ liệu (GD20) luôn tạo tệp kết quả mới và giữ nguyên tệp gốc. Màn hình So sánh siêu dữ liệu (GD21) cho phép đối chiếu trực tiếp trước và sau khi xử lý, giúp người dùng kiểm tra kết quả thay vì chỉ dựa vào thông báo của ứng dụng.

Bảng 21. Màn hình giao diện của nhóm 7

Mã màn hình	Tên màn hình	Chức năng được thực hiện
GD19	Xem siêu dữ liệu	metadata_inspect
GD20	Xóa siêu dữ liệu	metadata_sanitize
GD21	So sánh siêu dữ liệu	metadata_diff

Nhóm 8. Thông tin ứng dụng

Nhóm này cung cấp thông tin phiên bản của ứng dụng để phục vụ việc đối chiếu khi trao đổi tệp giữa các thiết bị. Thông tin bao gồm phiên bản ứng dụng, phiên bản giao diện lệnh, phiên bản định dạng kết và phiên bản bộ thuật toán mà ứng dụng đang sử dụng.

Bảng 22. Các chức năng của nhóm 8

Chức năng	Đầu vào	Xử lý	Kết quả
Xem thông tin phiên bản	Không có	Đọc các thông tin phiên bản được xác định khi xây dựng ứng dụng	Phiên bản ứng dụng, phiên bản giao tiếp với lõi xử lý, phiên bản định dạng kết và phiên bản bộ thuật toán

Giao diện tương ứng

Nhóm này không có màn hình riêng. Thông tin phiên bản được hiển thị trong mục “Giới thiệu” mở từ thanh tiêu đề của màn hình chính (GD01), qua đó đưa các thông tin kỹ thuật ra khỏi luồng thao tác chính nhưng vẫn bảo đảm khả năng tra cứu khi cần.

Trang chủ (GD01) đóng vai trò điểm bắt đầu, cung cấp các chức năng thường dùng và toàn bộ công cụ theo nhóm. Ngăn kéo điều hướng (GD02) tổ chức 19 công cụ thành năm nhóm theo mục đích sử dụng. Việc sử dụng ngăn kéo phù hợp với số lượng công cụ lớn, đồng thời bổ sung cho Trang chủ thay vì thay thế chức năng của màn hình này.

Bảng 23. Màn hình giao diện của nhóm 8

Mã màn hình	Tên màn hình	Chức năng được thực hiện
GD01	Trang chủ	app_info (qua khối Giới thiệu)
GD02	Ngăn kéo điều hướng	không gọi lệnh; điều hướng giữa các màn hình

4.2. Danh mục toàn bộ màn hình và kiểm tra hai chiều

Bảng dưới đây liệt kê toàn bộ màn hình của ứng dụng, nhóm chức năng tương ứng và các lệnh nghiệp vụ được gọi trên từng màn hình. Đây là bảng dùng để đối chiếu giữa giao diện và chức năng, bảo đảm mọi chức năng của ứng dụng đều có giao diện thực hiện.

Bảng 24. Danh mục toàn bộ màn hình và chức năng tương ứng

Mã	Màn hình	Nhóm	Chức năng nghiệp vụ được gọi
GD01	Trang chủ	—	app_info (qua khối Giới thiệu)
GD02	Ngăn kéo điều hướng	—	không gọi lệnh; điều hướng giữa các màn hình
GD03	Két an toàn	Nhóm 1	vault_create, vault_unlock, vault_lock, vault_change_passphrase, vault_meta, item_add, item_list, item_extract, sign_file, export_signing_public_key, integrity_check, integrity_hash, keys_split, keys_recover, verify_file

GD04	Khoá tệp	Nhóm 2	crypto_encrypt_file
GD05	Mở khoá tệp	Nhóm 2	crypto_decrypt_file, copy_file
GD06	Ký tệp	Nhóm 3	crypto_generate_signing_keypair, crypto_sign_file
GD07	Kiểm tra chữ ký	Nhóm 3	integrity_verify_signature
GD08	Lấy vân tay tệp	Nhóm 3	integrity_hash_file
GD09	Kiểm tra tệp chưa bị đổi	Nhóm 3	integrity_hash_file
GD10	Xác minh tệp tải về	Nhóm 3	integrity_verify_integrity
GD11	Chia nhỏ bí mật	Nhóm 4	shares_split_secret
GD12	Chia nhỏ tệp	Nhóm 4	shares_split_file
GD13	Ghép lại từ các mảnh	Nhóm 4	shares_recover_secret, copy_file
GD14	Chuyển mảnh bằng mã QR	Nhóm 4	shares_export_qr, shares_recover_from_qr
GD15	Giấu dữ liệu trong ảnh	Nhóm 5	stego_hide
GD16	Hiện dữ liệu ẩn	Nhóm 5	stego_extract, copy_file
GD17	Phát hiện dữ liệu ẩn	Nhóm 5	stego_detect
GD18	Chống giả mạo ảnh	Nhóm 6	watermark_embed, watermark_verify
GD19	Xem siêu dữ liệu	Nhóm 7	metadata_inspect
GD20	Xoá siêu dữ liệu	Nhóm 7	metadata_sanitise
GD21	So sánh siêu dữ liệu	Nhóm 7	metadata_diff

Bảng 25. Hai lệnh dùng chung cho toàn ứng dụng

Lệnh	Chạy ở đâu	Vai trò
app_info	Khởi “Giới thiệu” trên thanh tiêu đề	Hiển thị phiên bản ứng dụng, phiên bản giao tiếp với lõi xử lý, phiên bản định dạng kết và phiên bản bộ thuật toán
metadata_available	Chạy ngay khi khởi động, trước khi người dùng thao tác	Kiểm tra mô-đun siêu dữ liệu có sẵn sàng hay không; nếu không sẵn sàng, các màn hình GD19–GD21 được vô hiệu hoá và hiển thị cảnh báo

Tính đầy đủ của bảng này được kiểm tra hai chiều trực tiếp trên mã nguồn, chứ không bằng cách đọc lại tài liệu: *chiều thứ nhất* đi từ lõi ra giao diện, lấy danh sách lệnh mà lõi công bố và tìm xem mỗi lệnh có ít nhất một màn hình gọi tới hay không;

chiều thứ hai đi ngược lại, lấy mọi lệnh mà mã giao diện gọi và đối chiếu với danh sách lệnh của lõi. Chiều thứ nhất phát hiện chức năng đã làm nhưng người dùng không với tới được; chiều thứ hai phát hiện nút bấm gọi tới lệnh không tồn tại. Kết quả hiện tại: không có trường hợp nào ở cả hai chiều.

4.3. Nguyên tắc thiết kế giao diện

Với một ứng dụng bảo vệ dữ liệu, giao diện không chỉ trình bày mà còn quyết định người dùng có dùng đúng chức năng hay không, và có hiểu đúng kết quả hay không. Một thao tác sai vì giao diện gây hiểu nhầm cũng dẫn tới lộ dữ liệu như một lỗi mật mã. Vì vậy tác giả coi thiết kế giao diện là một phần của thiết kế an toàn, với bốn nguyên tắc áp dụng thống nhất:

- **Trình bày theo công việc cần thực hiện, không theo thuật toán.** Người dùng chọn chức năng theo nhu cầu thực tế, không cần biết bên trong dùng Argon2id hay Ed25519. Mười chín công cụ được tổ chức thành năm nhóm theo mục đích: kết an toàn; bảo vệ tệp; kiểm chứng nguồn gốc và toàn vẹn; sao lưu và khôi phục; kiểm tra và làm sạch dữ liệu. Những chức năng cùng nền tảng kỹ thuật nhưng khác mục đích được tách thành màn hình riêng — “lấy vân tay tệp” và “kiểm tra tệp với vân tay” đều dùng BLAKE3 nhưng là hai công việc khác nhau, gộp lại sẽ khiến người dùng phải tự suy luận.
- **Giảm tải nhận thức bằng phân tầng thông tin.** Mỗi màn hình ưu tiên hiển thị các bước cần thiết để hoàn thành công việc, đánh số theo trình tự. Thông tin kỹ thuật, hướng dẫn bổ sung và lưu ý về giới hạn của chức năng đặt trong mục thu gọn “Thông tin thêm”. Người dùng mới không bị ngợp; người muốn kiểm chứng vẫn có đủ thông tin.
- **Cảnh báo liên quan đến nguy cơ mất dữ liệu luôn được hiển thị.** Đây là ngoại lệ có chủ ý của nguyên tắc trên. Những cảnh báo liên quan trực tiếp đến nguy cơ mất khả năng truy cập dữ liệu — nhập sai mật khẩu khi thiết lập, hoặc không có phương thức khôi phục khi quên mật khẩu — được hiển thị thường trực ngay tại vị trí liên quan. Nguyên tắc: thông tin bổ sung có thể thu gọn, cảnh báo cần thiết để người dùng khỏi mất dữ liệu thì không.
- **Không để kết quả cũ bị hiểu nhầm là kết quả mới.** Với các chức năng trả về kết luận đạt/không đạt, kết quả của thao tác trước vẫn còn trên màn hình có thể bị hiểu là kết quả của thao tác mới — một hiểu nhầm nguy hiểm khi kết luận là “tệp toàn vẹn”. Vì vậy khi chuyển màn hình, ứng dụng xoá trạng thái kết quả, ẩn thẻ thông

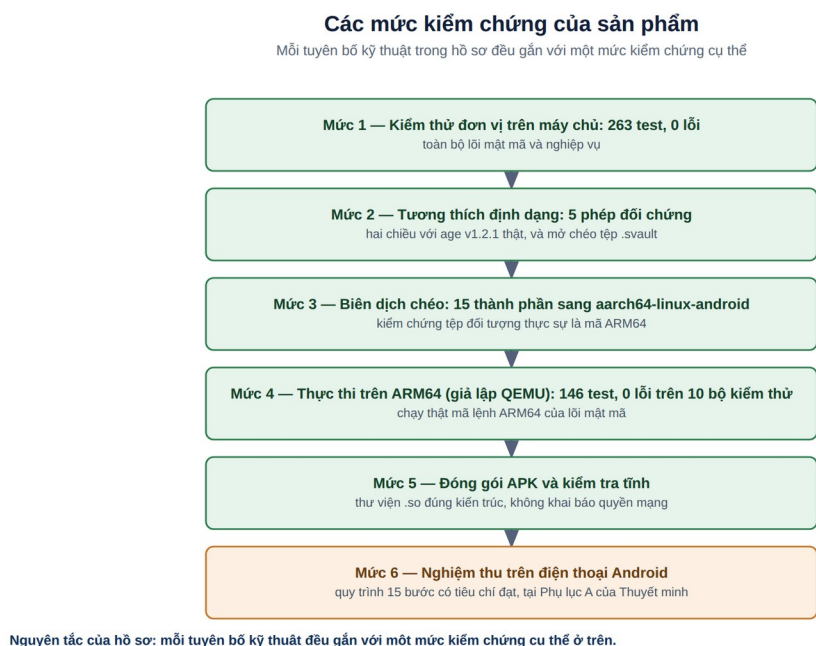
báo, xoá danh sách mảnh bí mật, đường dẫn tệp tạm và nội dung các trường mật khẩu. Cách xử lý này vừa tránh nhầm lẫn, vừa giảm khả năng thông tin nhạy cảm còn nằm lại trên giao diện.

Thích ứng cho màn hình cảm ứng. Ứng dụng dùng chung mã giao diện cho hai nền tảng và điều chỉnh bố cục theo nền tảng đang chạy, thay vì duy trì hai giao diện độc lập — cách này bảo đảm hai bản không lệch nhau về nội dung theo thời gian. Trên điện thoại, thanh điều hướng bên trái chuyển thành ngăn kéo trượt từ cạnh trái; các vùng tương tác có kích thước tối thiểu 44 điểm ảnh và giao diện có khoảng đệm phù hợp với vùng khuyết của màn hình. Việc bổ sung giao diện di động được kiểm tra để bảo đảm không làm thay đổi kết quả hiển thị của phiên bản máy tính: kết xuất trước và sau khi bổ sung trùng khớp theo phép so sánh ảnh được sử dụng. Toàn bộ chuỗi hiển thị hỗ trợ tiếng Việt và tiếng Anh, chuyển đổi ngay trong ứng dụng.

PHẦN V. KIỂM CHỨNG

5.1. Chiến lược kiểm chứng nhiều mức

Nguyên tắc mà nhóm tác giả đặt ra cho phần này: *mỗi tuyên bố kỹ thuật trong hồ sơ phải gắn với một cách kiểm tra bằng máy, và phải phân biệt rõ giữa “đã hiện thực” với “đã kiểm chứng bằng thực nghiệm”*. Hai điều đó khác nhau, và việc gộp chúng lại là cách phổ biến nhất khiến một hồ sơ kỹ thuật mất tin cậy.



Hình 6. Các mức kiểm chứng của sản phẩm

Kiểm chứng được tổ chức theo năm mức, từ mức rẻ và chạy thường xuyên đến mức đắt và gần thực tế nhất: kiểm thử đơn vị trên từng thành phần; kiểm thử tích hợp trên toàn bộ vòng đời nghiệp vụ; kiểm thử trên đúng kiến trúc bộ xử lý của điện thoại; đối chứng với công cụ chuẩn bên ngoài; và kiểm tra tĩnh chính gói cài đặt sẽ giao cho người dùng. Mức cuối cùng — nghiệm thu trên thiết bị thật — chưa thực hiện, và điều đó được nói rõ ở mục 5.6.

5.2. Bộ kiểm thử tự động

Mã nguồn hiện có 272 hàm kiểm thử tự động, phân bố theo từng thành phần như bảng dưới. Kết quả chạy toàn bộ trên máy chủ: 263 phép đạt, 0 lỗi.

Bảng 26. Phân bố hàm kiểm thử theo thành phần mã nguồn

Thành phần	Số hàm kiểm thử	Vai trò của thành phần
sv-core	22	Định dạng tệp kết, nghiệp vụ,

		phân cấp khoá, phân loại lỗi
sv-crypto	20	Hiện thực các nguyên hàm mật mã và chính sách tham số
sv-crypto-traits	6	Giao diện trừu tượng của nguyên hàm — nơi đặt các điểm nối
sv-platform	46	Nghiệp vụ trên tệp: khoá/mở khoá, ký, băm, chia bí mật theo ngưỡng
sv-stego	74	Giấu dữ liệu trong ảnh và phát hiện dấu hiệu dữ liệu ẩn
sv-watermark	11	Thuỷ văn dễ vỡ và khoanh vùng ảnh bị sửa
sv-age / sv-age-rs	13	Hai bản hiện thực mô-đun mã hoá nội dung, gồm cả phép đối chứng
sv-meta / sv-meta-rs	15	Hai bản hiện thực mô-đun siêu dữ liệu
sv-qr	8	Xuất và đọc mảnh bí mật qua mã QR
sv-sys-sodium / sv-sys-sss	7	Lớp bọc thư viện hệ thống
sv-types	4	Kiểu dữ liệu dùng chung và tập lỗi công bố ra giao diện
sv-app	46	Lớp ứng dụng, các lệnh nghiệp vụ và mô hình phiên làm việc
Tổng cộng	272	—

Số hàm kiểm thử được đếm tự động từ mã nguồn, không nhập tay.

5.3. Kiểm thử trên kiến trúc ARM64

Biên dịch thành công cho một kiến trúc không có nghĩa là chương trình chạy đúng trên kiến trúc đó. Sai khác về thứ tự byte, về cách căn chỉnh dữ liệu, hoặc về hành vi của thư viện hệ thống chỉ lộ ra khi mã thực sự chạy. Vì vậy lỗi được chạy dưới trình giả lập kiến trúc ARM64 — đúng kiến trúc bộ xử lý mà điện thoại Android dùng — với 10 bộ kiểm thử tập trung vào các thành phần mật mã và các lớp giao tiếp với thư viện hệ thống. Kết quả: 146 phép đạt, 0 lỗi.

Đây là mức kiểm chứng đắt hơn kiểm thử thông thường nhưng cần thiết, vì các thành phần gọi tới thư viện hệ thống viết bằng C là nơi khác biệt kiến trúc dễ gây lỗi nhất, mà lại đúng là các thành phần thực hiện phép mật mã.

5.4. Đối chứng tương thích định dạng với công cụ chuẩn

Ràng buộc bất biến định dạng (mục 2.3.3) là loại ràng buộc dễ bị vi phạm âm thầm: một thay đổi nhỏ trong bản hiện thực mới có thể sinh ra tệp mà chỉ chính nó đọc được. Không thể phát hiện điều đó bằng cách đọc mã, nên nhóm tác giả kiểm chứng bằng 5 phép thực nghiệm đối chứng hai chiều với công cụ chuẩn độc lập.

Bảng 27. Kiểm chứng khả năng tương thích định dạng giữa hai cách triển khai mô-đun mã hoá

Phép kiểm chứng	Nội dung	Kết quả
Đối chứng tệp mã hoá, chiều 1	Tệp được tạo bằng mô-đun mã hoá tích hợp trong ứng dụng, sau đó giải mã bằng công cụ chuẩn age v1.2.1	Đạt
Đối chứng tệp mã hoá, chiều 2	Tệp được tạo bằng công cụ chuẩn age v1.2.1, sau đó giải mã bằng mô-đun mã hoá tích hợp trong ứng dụng	Đạt
Mở chéo kết, chiều 1	Kết được tạo bằng phiên bản sử dụng tiến trình con, sau đó mở bằng phiên bản tích hợp trong ứng dụng	Đạt
Mở chéo kết, chiều 2	Kết được tạo bằng phiên bản tích hợp trong ứng dụng, sau đó mở bằng phiên bản sử dụng tiến trình con	Đạt
Kiểm tra cơ chế xác thực	Sau khi thay đổi cách triển khai mô-đun mã hoá, mật khẩu không đúng vẫn bị từ chối	Đạt

Nguồn: crates/sv-age-rs/tests/interop.rs và src-tauri/tests/vault_interop.rs. Công cụ đối chứng age v1.2.1 được tải từ nguồn chính thức; giá trị băm SHA-256 của tệp tải về được lưu để phục vụ kiểm tra và truy xuất nguồn gốc.

Giá trị của cách kiểm chứng này nằm ở chỗ công cụ đối chứng do bên thứ ba viết và không biết gì về sản phẩm. Nếu hai bên đọc được tệp của nhau theo cả hai chiều thì kết luận về tính tương thích không còn phụ thuộc vào lời khẳng định của nhóm tác giả.

5.5. Kiểm tra tính gói cài đặt

Mức kiểm chứng cuối cùng thực hiện được trên máy chủ là mở chính gói cài đặt sẽ giao cho người dùng và đọc nội dung bên trong. Cách này kiểm tra được những điều mà mã nguồn không bảo đảm: cấu hình đóng gói có đúng không, tài nguyên có thực sự nằm trong gói không, thư viện có đúng kiến trúc không.

Bảng 28. Kết quả kiểm tra tình gói cài đặt Android

Nội dung kiểm tra	Kết quả	Ý nghĩa
Kích thước gói	42,3 MB	Phù hợp với một ứng dụng có lõi mật mã tích hợp
Kiến trúc thư viện native	64-bit ARM aarch64	Đọc phần đầu tệp ELF trong gói — đúng kiến trúc của điện thoại Android
Quyền ứng dụng khai báo	Không có quyền nào	Bảng chứng kiểm tra được cho nguyên lý hoạt động ngoại tuyến tuyệt đối
Tài nguyên giao diện	Nhúng sẵn trong thư viện native	Giao diện đi kèm ứng dụng, không tải về từ mạng khi chạy
Giá trị băm SHA-256 của gói	f53096d046e0307e54d9933055012a50...	Cho phép đối chiếu đúng gói đã kiểm tra với gói được cài đặt

5.6. Chỉ tiêu kỹ thuật đạt được và phần chưa kiểm chứng

Bảng 29. Tổng hợp chỉ tiêu kỹ thuật

Chỉ tiêu	Giá trị đạt được	Cách xác định
Số chức năng nghiệp vụ	38 chức năng	Đếm trực tiếp từ mã nguồn
Số màn hình giao diện	21 màn hình	Đếm trực tiếp từ mã giao diện; ảnh chụp đủ ở Phụ lục B
Chức năng nghiệp vụ chưa có giao diện gọi tới	0	Đối chiếu lệnh của lõi với mã giao diện theo hai chiều
Số thành phần mã nguồn độc lập	15 thành phần	Độc cấu hình dự án
Số hàm kiểm thử tự động	272 hàm	Đếm trực tiếp từ mã nguồn
Kiểm thử trên máy chủ	263 đạt / 0 lỗi	Nhật ký chạy bộ kiểm thử
Kiểm thử lỗi trên kiến trúc ARM64 (10 bộ)	146 đạt / 0 lỗi	Chạy dưới trình giả lập kiến trúc
Kiểm chứng tương thích định dạng	5 phép đối chứng đạt	Đối chứng hai chiều với công cụ chuẩn age v1.2.1
Quyền ứng dụng yêu cầu	Không khai báo quyền nào	Độc tệp kê khai trong gói cài đặt
Nghiệm thu trên thiết bị Android thật	Chưa thực hiện	Quy trình 15 bước đã soạn, đặt tại Phụ lục A

Toàn bộ số liệu được sinh tự động từ mã nguồn và nhật ký kiểm thử, không nhập tay.

Phần chưa kiểm chứng — nêu rõ thay vì bỏ qua

Tại thời điểm lập hồ sơ, sản phẩm chưa được nghiệm thu trên thiết bị Android thật. Mọi kiểm chứng ở trên đều thực hiện trên máy chủ, kể cả phép chạy dưới trình giả lập kiến trúc ARM64.

Nhóm tác giả không suy diễn từ các kết quả đó thành kết luận về hành vi trên máy thật. Thay vào đó, Phụ lục A cung cấp quy trình nghiệm thu 15 bước, mỗi bước có thao tác và tiêu chí đạt cụ thể, để đơn vị tự xác nhận trước khi đưa vào sử dụng rộng rãi.

PHẦN VI. GIÁ TRỊ VÀ KHẢ NĂNG ÁP DỤNG

6.1. Giá trị đối với công tác huấn luyện

Ở mục 1.4 đã nêu một mâu thuẫn: sản phẩm dựng riêng để dạy học thường bị đơn giản hoá tới mức không dùng được thật, còn công cụ chuyên nghiệp thì quá phức tạp cho giờ thực hành. Cách hoá giải của sáng kiến là *không dựng hai sản phẩm*: học viên thực hành trên đúng công cụ được xây dựng cho nhu cầu sử dụng thật. Điều làm cho nó dùng được trong dạy học không phải sự đơn giản hoá, mà là bốn nguyên tắc giao diện ở mục 4.3 — đặc biệt là nguyên tắc phân tầng thông tin: phần kỹ thuật không bị bỏ đi mà được đưa vào mục “Thông tin thêm”, nơi giảng viên có thể mở ra đúng lúc cần giảng.

Bảng 30. Ảnh xạ chức năng của sản phẩm với nội dung giảng dạy

Chức năng	Nội dung giảng dạy minh họa
Tạo và mở kết an toàn	Dẫn xuất khoá từ mật khẩu; vì sao mật khẩu yếu vẫn nguy hiểm dù thuật toán mạnh
Khoá / mở khoá tệp	Mã hoá có xác thực; phân biệt bảo mật và toàn vẹn
Ký tệp và kiểm tra chữ ký	Mật mã khoá công khai; chứng minh nguồn gốc
Vân tay tệp và kiểm tra toàn vẹn	Hàm băm mật mã; ứng dụng trong kiểm tra tệp tải về
Chia bí mật k trong n	Chia sẻ bí mật ngưỡng; nguyên tắc tách quyền kiểm soát
Giấu tin và phát hiện giấu tin	Giấu tin trong ảnh; giới hạn của che giấu so với mã hoá
Thuỷ văn dễ vỡ	Phát hiện sửa đổi cục bộ trên ảnh
Xem và xoá siêu dữ liệu	Kênh lộ thông tin ngoài nội dung; quyền riêng tư trong ảnh số
Quy tắc phân loại lỗi	Tấn công dựa trên thông báo lỗi và cách phòng tránh
Mô hình mối đe dọa của sản phẩm	Cách xác định phạm vi bảo vệ và giới hạn của một biện pháp kỹ thuật

Một giá trị huấn luyện nữa ít gặp ở các công cụ thương mại: sản phẩm *chủ động dạy về giới hạn của chính nó*. Chức năng phát hiện dữ liệu ẩn không kết luận “ảnh sạch” mà chỉ nêu mức độ nghi ngờ trong phạm vi các phép kiểm tra đã thực hiện; chức năng kiểm tra thuỷ văn phân biệt “ảnh bị sửa” với “ảnh đã bị biến đổi khi lưu ở định dạng có mất dữ liệu”. Học viên qua đó hiểu rằng kết quả của một công cụ phân tích luôn phụ thuộc phương pháp và phạm vi — một bài học khó truyền đạt bằng lý thuyết.

Ngoài giá trị minh hoạ, mã nguồn mở cho phép mở rộng đào tạo theo hướng chuyên sâu: phân tích cách một nguyên lý được hiện thực, đánh giá mô hình mỗi đe dọa, hoặc rà soát mã nguồn để tìm điểm có thể cải thiện — tức là chuyển từ *dùng công cụ an toàn* sang *đánh giá được một hệ thống an toàn*.

6.2. Đề xuất khung bài thực hành

Phần này là đề xuất, chưa phải tài liệu đã biên soạn. Nhóm tác giả nêu ra để cho thấy sản phẩm có thể đưa vào chương trình theo cách nào, và để việc biên soạn về sau có sẵn khung.

Bảng 31. Đề xuất khung bốn bài thực hành trên sản phẩm

Bài	Nội dung thực hành	Kết quả học viên tự kiểm tra được
1. Mật khẩu và khoá	Tạo kết, thêm tệp, khoá lại, mở bằng mật khẩu đúng và sai; đổi mật khẩu	Thấy được mật khẩu không nằm trong tệp; thấy thời gian mở kết phản ánh chi phí dẫn xuất khoá
2. Toàn vẹn và nguồn gốc	Ký tệp, kiểm tra chữ ký, sửa một byte rồi kiểm tra lại; lấy vân tay tệp trên hai máy	Chữ ký chuyển từ hợp lệ sang không hợp lệ sau khi sửa; hai vân tay trùng nhau
3. Tách quyền kiểm soát	Chia bí mật 5 mảnh cần 3, thử khôi phục với 2 mảnh rồi với 3 mảnh	Dưới ngưỡng thì không khôi phục được và hệ thống báo còn thiếu mấy mảnh
4. Kênh lộ thông tin ngoài nội dung	Xem siêu dữ liệu ảnh chụp bằng điện thoại, xoá, rồi so sánh hai bản; giấu tệp vào ảnh rồi dùng chức năng phát hiện	Nhìn thấy nhóm toạ độ định vị biến mất; thấy che giấu không đồng nghĩa với không bị phát hiện

6.3. Giá trị trong tình huống truyền khẩn cấp

Trong tình huống ở mục 1.2, giá trị của sản phẩm nằm ở chỗ nó biến bốn biện pháp rời rạc thành một quy trình làm được trên chính thiết bị đang có, không cần máy tính, không cần mạng, không cần dịch vụ bên ngoài. Trình tự đề xuất: xoá siêu dữ liệu của tệp trước; mã hoá bằng mật khẩu mạnh; ký số để bên nhận xác minh được nguồn gốc; và khi tính chất công việc đòi hỏi thì chia thành nhiều mảnh gửi theo các kênh độc lập, kèm trao mật khẩu qua một kênh khác với kênh truyền tệp.

Cần nói thẳng giới hạn: các biện pháp này *giảm rủi ro*, không *loại bỏ* rủi ro, và chúng không thay đổi việc tài liệu đó có được phép truyền hay không. Ba giới hạn cụ thể mà người dùng phải biết: nếu thiết bị đã bị chiếm quyền điều khiển thì mọi biện pháp trong ứng dụng đều mất tác dụng; nếu mật khẩu được trao qua chính kênh truyền

tệp thì mã hoá gần như vô nghĩa; và nếu quên mật khẩu mà không tạo trước mảnh phục hồi thì dữ liệu không lấy lại được.

6.4. Điều kiện triển khai, giới hạn và hướng phát triển

Điều kiện triển khai rất đơn giản: một thiết bị Android, không cần máy chủ, không cần kết nối mạng, không yêu cầu quyền quản trị thiết bị. Đây là hệ quả trực tiếp của nguyên lý hoạt động ngoại tuyến — thứ ban đầu là một ràng buộc an toàn, nhưng hoá ra cũng là thứ làm cho việc triển khai gần như không có chi phí.

Bảng 32. Mức độ hoàn thành theo hạng mục

Hạng mục	Mức độ	Cách xác định
Thiết kế kiến trúc, định dạng tệp kết và sơ đồ phân cấp khoá	Hoàn thành	Tài liệu kiến trúc và mã nguồn
Lỗi bảo vệ dữ liệu và toàn bộ nghiệp vụ	Hoàn thành	Bộ kiểm thử tự động chạy đạt trên máy chủ
Mô-đun xử lý siêu dữ liệu bằng Rust	Hoàn thành	Kiểm thử tự động trên ảnh có siêu dữ liệu
Tương thích định dạng giữa hai bản hiện thực	Hoàn thành	Đối chứng hai chiều với công cụ chuẩn age v1.2.1
Biên dịch và thực thi lỗi trên kiến trúc ARM64	Hoàn thành	Kiểm tra tệp đối tượng; chạy bộ kiểm thử dưới trình giả lập kiến trúc
Giao diện cho màn hình điện thoại	Hoàn thành	Kết xuất và kiểm tra bố cục ở kích thước điện thoại
Đóng gói tệp cài đặt Android	Hoàn thành	Kiểm tra tính nội dung gói cài đặt
Kiểm thử nghiệm thu trên thiết bị Android	Có quy trình nghiệm thu	Quy trình 15 bước có tiêu chí đạt cho từng bước, tại Phụ lục A
Tích hợp kho khoá phần cứng của Android	Định hướng phát triển	Chưa hiện thực trong phiên bản này

Hướng phát triển.

- **Mở rộng kiểm thử nghiệm thu trên nhiều dòng máy.** Thực hiện các kịch bản ở Phụ lục A trên nhiều dòng điện thoại và phiên bản Android khác nhau, ghi nhận kết quả để đánh giá khả năng tương thích và mức độ ổn định.
- **Tích hợp kho khoá phần cứng và xác thực sinh trắc.** Nghiên cứu dùng vùng lưu khoá được Android và phần cứng thiết bị bảo vệ cho một số khoá nằm ngoài hệ thống khoá của kết; bổ sung tùy chọn xác thực bằng vân tay. Lưu ý thiết kế: không đưa khoá chính của kết vào kho khoá phần cứng, vì như vậy sẽ phá vỡ tính chất tệp kết tự bảo vệ khi mang sang thiết bị khác.

- **Mở rộng phạm vi định dạng của mô-đun siêu dữ liệu.** Bổ sung khả năng xem và loại bỏ siêu dữ liệu với các định dạng ảnh, video khác, đồng thời giữ nguyên tắc chỉ báo thành công khi kết quả xử lý đã được kiểm tra.
- **Xây dựng bộ bài giảng và bài thực hành kèm theo.** Biên soạn tài liệu hướng dẫn giảng viên, phiếu bài thực hành và bộ dữ liệu mẫu trên cơ sở khung đề xuất ở mục 6.2.
- **Đánh giá độc lập và mở rộng nền tảng.** Tổ chức rà soát mã nguồn và kiểm thử độc lập bởi đồng nghiệp hoặc học viên có chuyên môn. Trên cơ sở kiến trúc lõi dùng chung đã có, việc mở rộng sang nền tảng khác chỉ cần bổ sung các thành phần phụ thuộc nền tảng mà vẫn dùng chung lõi và định dạng.

PHỤ LỤC A. QUY TRÌNH KIỂM THỬ NGHIỆM THU TRÊN THIẾT BỊ ANDROID

Phụ lục này quy định quy trình nghiệm thu trên thiết bị Android thật. Mỗi bước có thao tác và tiêu chí đạt cụ thể để kết quả kiểm tra và đối chiếu được; cột Kết quả để trống cho người thực hiện ghi nhận. Quy trình bao phủ đủ tám nhóm chức năng và kết thúc bằng một phép kiểm tra liên nền tảng.

Bảng 33. Quy trình kiểm thử nghiệm thu trên thiết bị Android

TT	Nội dung	Thao tác	Tiêu chí đạt	Kết quả
1	Cài đặt	Cài tệp APK và mở ứng dụng	Ứng dụng khởi động, hiển thị màn hình chính bằng tiếng Việt	
2	Không có quyền mạng	Xem mục Quyền ứng dụng trong Cài đặt hệ thống	Không có quyền truy cập mạng nào được liệt kê	
3	Tạo kết	Tạo kết mới, đặt mật khẩu	Tệp kết được tạo, ứng dụng báo thành công	
4	Thêm và trích xuất tệp	Thêm một tệp, khoá kết, mở lại, trích xuất	Tệp trích xuất giống hệt tệp gốc	
5	Từ chối mật khẩu sai	Mở kết bằng mật khẩu sai	Từ chối, thông báo rõ ràng, không tiết lộ thông tin khác	
6	Phát hiện sửa đổi	Sửa một byte của tệp kết rồi mở lại	Báo tệp bị hỏng hoặc bị sửa, không mở	
7	Khoá và mở khoá tệp đơn	Khoá một ảnh, mở lại bằng đúng mật khẩu	Ảnh khôi phục nguyên vẹn	
8	Ký và kiểm tra chữ ký	Tạo cặp khoá, ký tệp, kiểm tra chữ ký	Kiểm tra đạt; sau khi sửa tệp thì kiểm tra không đạt	
9	Vân tay tệp	Lấy vân tay cùng một tệp trên hai thiết bị	Hai giá trị vân tay trùng nhau	
10	Chia và khôi phục khoá	Chia bí mật 3 mảnh cần 2, khôi phục bằng 2 mảnh	Khôi phục đúng; dùng 1 mảnh thì không khôi phục được	
11	Giấu tin và phát hiện	Giấu tệp vào ảnh, rồi dùng chức năng phát hiện	Trích xuất đúng tệp; chức năng phát hiện ghi nhận dấu hiệu	

12	Xem siêu dữ liệu ảnh	Chọn ảnh chụp bằng điện thoại rồi bấm Xem	Liệt kê các thẻ; ảnh có định vị thì thấy nhóm tọa độ	
13	Xoá siêu dữ liệu ảnh	Xoá siêu dữ liệu ảnh đó rồi xem lại bản đã xoá	Bản sạch không còn thẻ; ảnh gốc nguyên vẹn; ảnh vẫn mở xem được	
14	Thuỷ vân chống giả mạo	Đóng dấu một ảnh, sửa một vùng, kiểm tra lại	Phát hiện ảnh đã bị sửa và chỉ ra vùng bị can thiệp	
15	Tương thích liên nền tảng	Mở tệp kết tạo trên máy tính bằng ứng dụng di động	Mở được bằng đúng mật khẩu	

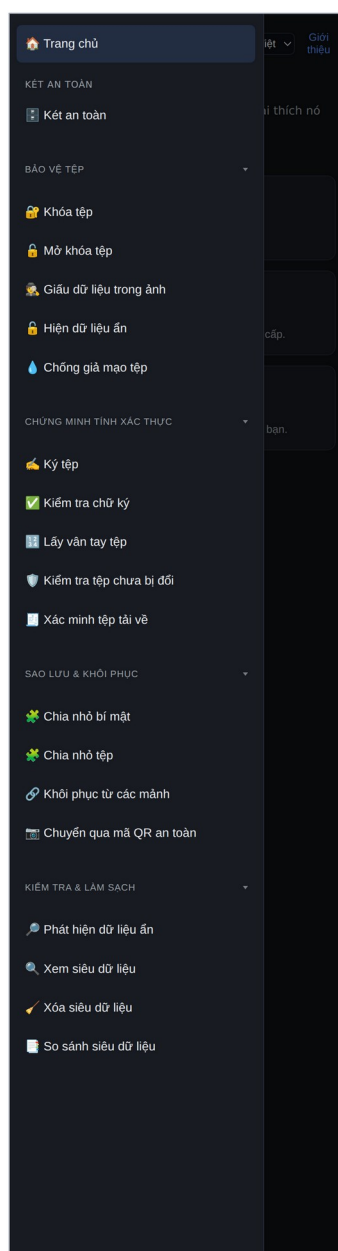
PHỤ LỤC B. ẢNH CHỤP TOÀN BỘ MÀN HÌNH GIAO DIỆN

Phụ lục này trình bày ảnh chụp đủ 21 màn hình giao diện của ứng dụng, sắp xếp theo thứ tự trong thanh điều hướng. Mã màn hình dưới mỗi ảnh (GD01–GD21) thống nhất với mã dùng ở mục 4.1 và 4.2, giúp đối chiếu giữa chức năng được mô tả và màn hình thực hiện nó.

Ảnh được chụp ở kích thước màn hình điện thoại. Với màn hình có nội dung dài hơn khung hiển thị, ảnh chụp toàn bộ phần nội dung cuộn được, nên chiều cao ảnh có thể lớn hơn một khung màn hình thực tế. Các mục “Thông tin thêm” được giữ ở trạng thái thu gọn, đúng như trạng thái mặc định khi mở màn hình.



GD01. Trang chủ



GD02. Ngăn kéo điều hướng

Hình 7. GD01 — Trang chủ; GD02 — Ngăn kéo điều hướng

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

Kết an toàn

ĐÁ KHÓA

Mở kết an toàn

Kết an toàn là một hộp được bảo vệ bằng mật khẩu để chứa các tệp của bạn.

Tệp kết

Chọn tệp kết của bạn...

Duyệt...

Mật khẩu

mật khẩu

Mở kết

Tạo kết mới

Lưu kết mới thành

Chọn nơi lưu...

Lưu thành...

Mật khẩu

mật khẩu

Xác nhận mật khẩu

nhập lại mật khẩu

Gõ sai ở đây sẽ khiến bạn mất quyền truy cập vĩnh viễn.

Thiết lập khôi phục (tùy chọn)

Tạo kết

Thêm: khôi phục từ các mảnh, hoặc kiểm tra tệp kết

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

Khóa tệp bằng mật khẩu

Biến bất kỳ tệp nào thành tệp đã khóa mà chỉ mật khẩu của bạn mới mở được.

Thông tin thêm

1 Chọn tệp cần khóa

Kéo thả tệp vào đây, hoặc bấm Duyệt...

Duyệt...

2 Đặt mật khẩu

mật khẩu

Xác nhận mật khẩu

nhập lại mật khẩu

Gõ sai ở đây là không thể khôi phục — tệp sẽ không bao giờ mở được.

3 Nơi lưu tệp đã khóa

/đường-dẫn/tới/tệp.svenc

Lưu thành...

Khóa tệp

GD03. Kết an toàn

GD04. Khoá tệp

Hình 8. GD03 — Kết an toàn; GD04 — Khoá tệp

48

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

🔒 **Mở khóa tệp**

Mở một tệp đã khóa (.svenc) bằng mật khẩu của nó.

► Thông tin thêm

1 Chọn tệp đã khóa

Kéo thả tệp .svenc vào đây, hoặc Duyệt...

Duyệt...

2 Mật khẩu

mật khẩu

3 Nơi lưu tệp đã mở

/đường-dẫn/tới/tệp-khôi-phục

Lưu thành...

Mở khóa tệp

GD05. Mở khoá tệp

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

🔑 **Ký tệp**

Chứng minh một tệp đến từ bạn và chưa thay đổi kể từ đó.

► Thông tin thêm

Trước tiên, danh tính ký của bạn

Lưu danh tính vào thư mục

/đường-dẫn/tới/thư-mục-xuất

Duyệt...

Đặt tên cho danh tính này

khoa-ky-cua-toi

Mật khẩu (bảo vệ khóa bí mật)

mật khẩu

Xác nhận mật khẩu

nhập lại mật khẩu

Tạo danh tính ký

Ký một tệp

Ký bất kỳ tệp nào bằng khóa bí mật của bạn, ghi tệp <tệp>.minisig bên cạnh nó.

Tệp cần ký

/đường-dẫn/tới/tai-lieu.pdf

Duyệt...

Khóa bí mật của bạn (.svkey)

/đường-dẫn/tới/khoa-ky-cua-toi.svkey

Duyệt...

Mật khẩu

mật khẩu

Ký tệp

GD06. Ký tệp

Hình 9. GD05 — Mở khoá tệp; GD06 — Ký tệp

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

✓

Kiểm tra chữ ký

Xác nhận một tệp đã được ký bởi một người cụ thể và chưa thay đổi.

► Thông tin thêm

1 Tệp

/đường-dẫn/tới/tai-lieu.pdf

Duyệt...

2 Chữ ký (.minisig)

/đường-dẫn/tới/tai-lieu.pdf.minisig

Duyệt...

3 Khóa công khai của họ (.pub)

/đường-dẫn/tới/nguoi-ky.pub

Duyệt...

Kiểm tra

GD07. Kiểm tra chữ ký

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

1 2 3 4

Lấy vân tay tệp

Lấy một mã nhận dạng duy nhất (BLAKE3) của đúng nội dung tệp.

► Thông tin thêm

Chọn một tệp

Kéo thả tệp vào đây, hoặc Duyệt...

Duyệt...

Lấy vân tay

GD08. Lấy vân tay tệp

Hình 10. GD07 — Kiểm tra chữ ký; GD08 — Lấy vân tay tệp

50

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

Kiểm tra tệp chưa bị đổi

Xác nhận một tệp văn khớp với văn tay bạn được cung cấp.

► Thông tin thêm

1 Chọn tệp

Kéo thả tệp vào đây, hoặc Duyệt...

Duyệt...

2 Dán văn tay bạn được cung cấp

vd. ab12cd... (64 ký tự)

Khoảng trắng và chữ hoa/thường không quan trọng.

Kiểm tra

GD09. Kiểm tra tệp chưa bị đổi

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

Xác minh tệp tải về

Kiểm tra một tệp với văn tay và/hoặc chữ ký đã công bố của nó — trong một bước.

► Thông tin thêm

1 Chọn tệp

Kéo thả tệp vào đây, hoặc Duyệt...

Duyệt...

2 Văn tay mong đợi (tùy chọn)

vd. ab12cd... (64 ký tự)

Khoảng trắng và chữ hoa/thường không quan trọng.

3 Chữ ký (tùy chọn, .minisig)

/đường-dẫn/tới/tệp.minisig

Duyệt...

4 Khóa công khai của người ký (cần khi có chữ ký, .pub)

/đường-dẫn/tới/nguoi-ky.pub

Duyệt...

Xác minh

GD10. Xác minh tệp tải về

Hình 11. GD09 — Kiểm tra tệp chưa bị đổi; GD10 — Xác minh tệp tải về

51

🔒

Bộ công cụ Bảo...

Tiếng Việt

▼

Giới thiệu

🧩 Chia nhỏ bí mật

Chia một mật khẩu, khóa, hay ghi chú thành nhiều mảnh — bất kỳ số lượng đã chọn nào gộp lại đều khôi phục được.

► Thông tin thêm

1 Bí mật cần chia

Gõ hoặc dán bí mật (mật khẩu, khóa, cụm từ khôi phục...)

Ở lại trên thiết bị này. Nó sẽ không hiện lại sau khi bạn chia.

Tổng số mảnh

Số mảnh cần để khôi phục

3

2

2 Lưu các mảnh vào một thư mục

Chọn một thư mục...

Duyệt...

Chia thành các mảnh

GD11. Chia nhỏ bí mật

🔒

Bộ công cụ Bảo...

Tiếng Việt

▼

Giới thiệu

🧩 Chia nhỏ tệp

Chia một tệp thành nhiều mảnh — bất kỳ số lượng đã chọn nào gộp lại đều khôi phục được.

► Thông tin thêm

1 Chọn tệp cần chia

Kéo thả tệp vào đây, hoặc bấm Duyệt...

Duyệt...

Tổng số mảnh

Số mảnh cần để khôi phục

3

2

2 Lưu các mảnh vào một thư mục

Chọn một thư mục...

Duyệt...

Chia thành các mảnh

GD12. Chia nhỏ tệp

Hình 12. GD11 — Chia nhỏ bí mật; GD12 — Chia nhỏ tệp

52

🔒

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

🔗 Khôi phục từ các mảnh

Dựng lại một bí mật hoặc tệp từ đủ số mảnh của nó, cùng tệp dữ liệu (payload).

► Thông tin thêm

1 Các tệp mảnh

Kéo thả tệp mảnh vào đây, hoặc bấm Thêm tệp mảnh...

Thêm tệp mảnh...

Hoặc dán mã mảnh (mỗi dòng một mã)

Dán mã mảnh Base64, mỗi dòng một mã (tùy chọn nếu bạn đã thêm tệp ở trên)

2 Tệp dữ liệu (payload)

Chọn tệp .payload.svss...

Duyệt...

3 Nơi lưu kết quả khôi phục

/đường-dẫn/tới/ket-qua-khoi-phuc

Lưu thành...

Khôi phục

GD13. Ghép lại từ các mảnh

🔒

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

📄 Chuyển qua mã QR an toàn

Chuyển các mảnh Chia sẻ Bí mật giữa các thiết bị dưới dạng mã QR — biến các mảnh thành ảnh QR, và khôi phục từ ảnh QR đã quét/lưu.

► Thông tin thêm

1 Dán mã mảnh để biến thành ảnh QR (mỗi dòng một mã)

Dán mã mảnh Base64 từ "Chia nhỏ bí mật", mỗi dòng một mã

2 Lưu các ảnh QR vào một thư mục

Chọn một thư mục...

Duyệt...

Tạo ảnh QR

🔗 Khôi phục từ ảnh QR

Dựng lại một bí mật từ đủ số ảnh QR, cùng tệp dữ liệu (payload).

► Thông tin thêm

1 Các tệp ảnh QR (PNG/JPEG)

Kéo thả ảnh QR vào đây, hoặc bấm Thêm ảnh QR...

Thêm ảnh QR...

► Hãy thêm ít nhất số mảnh "cần để khôi phục".

2 Tệp dữ liệu (payload)

Chọn tệp .payload.svss...

Duyệt...

3 Nơi lưu kết quả khôi phục

/đường-dẫn/tới/ket-qua-khoi-phuc

Lưu thành...

Khôi phục từ QR

GD14. Chuyển mảnh bằng mã QR

Hình 13. GD13 — Ghép lại từ các mảnh; GD14 — Chuyển mảnh bằng mã QR

53

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

👤

Giấu dữ liệu bên trong ảnh

Mã hóa một tệp bằng mật khẩu, rồi giấu nó bên trong ảnh PNG, BMP hoặc JPEG.

► Thông tin thêm

1 Chọn ảnh nền (PNG, BMP hoặc JPEG)

Kéo thả PNG/BMP/JPEG vào đây, hoặc Duyệt...

Duyệt...

2 Chọn tệp cần giấu

Kéo thả tệp bí mật vào đây, hoặc Duyệt...

Duyệt...

3 Đặt mật khẩu

mật khẩu

Xác nhận mật khẩu

nhập lại mật khẩu

Gõ sai ở đây là không thể khôi phục — dữ liệu giấu sẽ không bao giờ đọc được.

4 Nơi lưu ảnh có dữ liệu giấu

/đường-dẫn/tới/kết-qua.png

Lưu thành...

☒ Rải dữ liệu khắp ảnh (khuyến dùng)

Giấu dữ liệu

GD15. Giấu dữ liệu trong ảnh

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

🔒

Hiện dữ liệu giấu trong ảnh

Khôi phục một tệp đã được giấu bằng “Giấu dữ liệu”, dùng mật khẩu của nó.

► Thông tin thêm

1 Chọn ảnh có dữ liệu giấu

Kéo thả PNG/BMP/JPEG vào đây, hoặc Duyệt...

Duyệt...

2 Mật khẩu

mật khẩu

3 Chọn thư mục đích

/đường-dẫn/tới/thư-mục-đích

Chọn thư mục...

Hiện dữ liệu

GD16. Hiện dữ liệu ẩn

Hình 14. GD15 — Giấu dữ liệu trong ảnh; GD16 — Hiện dữ liệu ẩn

54

🔒

Bộ công cụ Bảo...

Tiếng Việt

▼

Giới thiệu

🔍

Phát hiện dữ liệu ẩn

Quét ảnh tìm dấu hiệu dữ liệu ẩn. Mang tính suy đoán — có thể cảnh báo nghi ngờ, nhưng không bao giờ chứng minh là sạch.

► Thông tin thêm

1 Chọn ảnh cần quét (PNG, BMP hoặc JPEG)

Kéo thả PNG/BMP/JPEG vào đây, hoặc Duyệt...

Duyệt...

Quét ảnh

GD17. Phát hiện dữ liệu ẩn

🔒

Bộ công cụ Bảo...

Tiếng Việt

▼

Giới thiệu

💧

Chống giả mạo ảnh

Đóng một dấu vô hình, khóa bằng mật khẩu vào ảnh để sau này bạn có thể chứng minh nó chưa bị sửa.

► Thông tin thêm

1 Chọn ảnh cần đánh dấu (PNG hoặc BMP)

Kéo thả PNG/BMP vào đây, hoặc Duyệt...

Duyệt...

2 Đặt mật khẩu (khóa cho dấu)

mật khẩu

3 Nơi lưu ảnh đã đánh dấu (PNG hoặc BMP)

/đường-dẫn/tới/anh-da-danh-dau.png

Lưu thành...

Thêm dấu chống giả mạo

🔍

Kiểm tra giả mạo

Xác minh một ảnh đã đánh dấu với mật khẩu của bạn.

1 Chọn ảnh đã đánh dấu (PNG hoặc BMP)

Kéo thả ảnh PNG/BMP đã đánh dấu vào đây, ho...

Duyệt...

2 Mật khẩu

mật khẩu

Kiểm tra giả mạo

GD18. Chống giả mạo ảnh

Hình 15. GD17 — Phát hiện dữ liệu ẩn; GD18 — Chống giả mạo ảnh

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

Xem siêu dữ liệu

Xem siêu dữ liệu ẩn mà một tệp mang theo — máy ảnh, vị trí, tác giả, phần mềm, dấu thời gian.

► Thông tin thêm

1 Chọn tệp cần xem

Kéo thả bất kỳ tệp nào vào đây, hoặc Duyệt...

Duyệt...

Xem

GD19. Xem siêu dữ liệu

Bộ công cụ Bảo...

Tiếng Việt

Giới thiệu

Xóa siêu dữ liệu

Ghi một bản sao sạch của tệp với siêu dữ liệu nhúng đã được loại bỏ.

► Thông tin thêm

1 Chọn tệp cần làm sạch

Kéo thả tệp vào đây, hoặc Duyệt...

Duyệt...

2 Nơi lưu bản sao đã làm sạch

/đường-dẫn/tới/tệp-da-lam-sach

Lưu thành...

Xóa siêu dữ liệu

GD20. Xóa siêu dữ liệu

Hình 16. GD19 — Xem siêu dữ liệu; GD20 — Xóa siêu dữ liệu

56

Bộ công cụ Bả...

Tiếng Việt ▾

Giới thiệu

So sánh siêu dữ liệu

Xem siêu dữ liệu nhúng của hai tệp khác nhau ra sao — gì được thêm, bị xóa, hay thay đổi.

► Thông tin thêm

1 Tệp thứ nhất (A)

Kéo thả tệp vào đây, hoặc Duyệt...

Duyệt...

2 Tệp thứ hai (B)

Kéo thả tệp vào đây, hoặc Duyệt...

Duyệt...

So sánh

GD21. So sánh siêu dữ liệu

Hình 17. GD21 — So sánh siêu dữ liệu

PHỤ LỤC C. DANH MỤC LỆNH NGHIỆP VỤ CỦA LỖI

Danh sách 38 lệnh nghiệp vụ mà lỗi công bố cho giao diện, đọc trực tiếp từ mã nguồn. Đây là danh sách dùng cho phép kiểm tra hai chiều ở mục 4.2.

Bảng 34. Danh mục lệnh nghiệp vụ của lỗi

Lệnh	Lệnh	Lệnh
app_info	vault_create	vault_unlock
vault_lock	vault_change_passphrase	vault_meta
export_signing_public_key	item_list	item_add
item_extract	integrity_check	integrity_hash
sign_file	verify_file	keys_split
keys_recover	integrity_hash_file	integrity_verify_signature
integrity_verify_integrity	crypto_encrypt_file	crypto_decrypt_file
crypto_generate_signing_keypair	crypto_sign_file	shares_split_secret
shares_split_file	shares_recover_secret	shares_export_qr
shares_recover_from_qr	copy_file	stego_hide
stego_extract	stego_detect	metadata_inspect
metadata_sanitise	metadata_diff	metadata_available
watermark_embed	watermark_verify	

Hà Nội, ngày 09 tháng 9 năm 2026

XÁC NHẬN CỦA ĐƠN VỊ

CHỦ NHIỆM SÁNG KIẾN

Thượng úy Trần Thị Tới